Computers & Security 135 (2023) 103514

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Evaluating the applicability of hardware trust anchors for automotive applications ☆

Christian Plappert [a,*], Dominik Lorych [a], Michael Eckel [a], Lukas Jäger [a], Andreas Fuchs [a,1], Ronald Heddergott [b]

[a] Fraunhofer SIT | ATHENE, Darmstadt, Germany
[b] CARIAD SE, Berlin, Germany

ARTICLE INFO

Keywords:
Automotive
Hardware trust anchor (HTA)
Evaluation
Trusted Platform Module (TPM)
Hardware Security Module (HSM)
EVITA
Secure Hardware Extension (SHE)
ARM TrustZone
Device Identifier Composition Engine (DICE)
Intel Software Guard Extensions (SGX)

ABSTRACT

The automotive trend towards autonomous driving and advanced connected services increases both complexity of the vehicle internal network and the connections to its environment. This introduced complexity further broadens the vehicle cyberattack surface.

As mitigation strategy, state-of-the-art security mechanisms utilize so-called hardware trust anchors (HTAs) to protect security-sensitive data and processes in shielded locations that are isolated utilizing hardware security mechanisms. However, there is a variety of different HTAs with different functionality and security guarantees and there is currently no work done that compares and evaluates them against current and emerging automotive requirements.

In this work, we evaluate the applicability of various HTAs to secure modern as well as upcoming future automotive applications. For this, we analyze and evaluate HTAs that are already established in the automotive field as well as promising HTAs from other domains. We extend our preliminary work (Plappert et al., 2022b) by increasing the range of the analyzed HTAs with solutions that are feasible for the most resource constrained automotive controllers and technologies that become feasible to be utilized by the introduction of high-performance controllers in future automotive architectures. We assess the different HTAs based on the evaluation criteria and in accordance to automotive requirements.

1. Introduction

Recent automotive trends towards strong connectivity and fully automated driving, is reflected in the growing complexity of in-vehicle architectures. The software deployed within the heterogeneous and heavily distributed vehicle network already surpasses 100 million lines of code, making it already more complex than Facebook or whole operating systems like Windows 7 or Debian 5.0 (McCandless et al., 2015). With more connections to the outside world and the development towards autonomous driving, this complexity is expected to grow further and will then not only cover the in-vehicle but increasingly also the extra-vehicle communication to support modern vehicle services.

As the complexity grows, also the capabilities of the in-vehicle network technologies and its connected computing nodes, the so-called Electronic Control Units (ECUs), needs to improve to meet the growing demand for data processing. This development will also influence the design of upcoming automotive Electrical / Electronic architectures (E / E). Current domain-based architectures will transition to architectures that are dominated by a few central high-performance ECUs, so-called High-Performance Computers (HPCs), that are interconnected via high-bandwidth networks and are responsible for the new more resource-intensive services with strong requirements towards safety and performance (Dibaei et al., 2020). This more powerful vehicle backbone is then connected to a legacy network with the currently deployed more resource constrained ECUs and network technologies.

The development towards complexity in both internal and external communication and software broadens also the cyberattack surface of modern and upcoming vehicles. In particular, the external interfaces are

☆ This work extends the conference paper (Plappert et al., 2022b).

* Corresponding author.
E-mail addresses: christian.plappert@sit.fraunhofer.de (C. Plappert), dominik.lorych@sit.fraunhofer.de (D. Lorych), michael.eckel@sit.fraunhofer.de (M. Eckel), lukas.jaeger@sit.fraunhofer.de (L. Jäger), andreas.fuchs@sit.fraunhofer.de (A. Fuchs), ronald.heddergott@cariad.technology (R. Heddergott).

[1] The work on the conference paper was carried out while still being at Fraunhofer SIT.

https://doi.org/10.1016/j.cose.2023.103514
Received 6 June 2023; Received in revised form 29 August 2023; Accepted 26 September 2023
Available online 2 October 2023
0167-4048/© 2023 The Authors. Published by Elsevier Ltd. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

highly critical and are used as first step in typical cyberattack chains as recent cyberattacks that target connected vehicles show (Plappert et al., 2021b). These attacks range from stealing vehicles (Osborne, 2018) to the hijacking and remote controlling of vehicles (Greenberg, 2015).

To mitigate against a variety of current cyberthreats, state-of-the-art security approaches utilize so-called Hardware Trust Anchors (HTAs) that provide isolated environments bootstrapped by hardware security mechanisms to enable a secure storage and processing of security-sensitive data. HTAs come in a variety of variations, shield the isolated environment against the possibly compromised host, and mitigate against logical attacks targeted at software vulnerabilities and, depending on the particular HTA, even against physical side channel or (semi-) invasive attacks that are directly targeted against the hardware security mechanisms.

HTAs are started to be more widely deployed in the ECUs across the whole vehicle (Ring et al., 2018). Secure Hardware Extension (SHE) and the EVITA Hardware Security Module (HSM) are the most prominent specifications of HTA variants for the automotive domain and are used to secure the majority of vehicle ECUs. The hardware manufacturers implement these HTAs specifications under their own product names. For example, Infineon Aurix (Infineon Technologies AG, 2020b), the Renesas Intelligent Cryptographic Unit (ICU) HSM (Renesas, 2016), and the NXP Semiconductors Hardware Security Engine (HSE) (Simacsek, 2019) provide implementation for the SHE and EVITA HTAs.

Next to these already established HTAs, there are also promising new HTAs that are typically deployed in other domains and rather new to the automotive domain. For example, the Trusted Platform Module (TPM), which is already dominant in the consumer electronics domain, is started to be integrated into first vehicle architectures (Infineon Technologies AG, 2019). Moreover, the Device Identifier Composition Engine (DICE) is targeted to secure more resource constrained devices in the embedded environments. In the automotive context, it is suitable to secure, e.g., very resource constraint legacy ECUs and sensors. In contrast, the Intel Software Guard Extensions (SGX) is targeted at application processors and thus feasible to be used in upcoming HPC-based architectures and corresponding use cases.

This short overview alone shows the variety of different HTAs that may be feasible to secure current and also upcoming future E/E architectures. Each of these HTAs may have their own advantages and disadvantages regarding different evaluation criteria. In particular regarding upcoming automotive trends, predominant HTAs specifications like EVITA and SHE, which are quite dated, may not be feasible to secure future automotive use cases. On the other hand, also HTAs from other domains need to be analyzed and evaluated regarding their feasibility to be used to secure current and upcoming use cases.

Contribution Thus, we dedicate this work to the analysis and evaluation of the applicability of established as well as promising new HTAs to secure current and future automotive use cases. In this work, we extend our own preliminary work presented in Plappert et al. (2022b) and increase the range of the analyzed HTAs with HTAs for the most resource constrained automotive controllers and HTAs that are feasible to utilize the increased performance introduced by the HPCs. We evaluate the different HTAs against evaluation criteria that we derive from an automotive domain analysis that includes corresponding use cases and attacker model.

To the best of our knowledge, there is no other recent work dealing with the analysis and evaluation of HTAs regarding their applicability in the automotive domain. In particular, there is no work that considers our automotive domain requirements in combination with the analysis of the corresponding specifications of a variety of different HTAs.

In short, we make the following contributions:

1. We design a new HTA evaluation approach that also involves current and expected upcoming requirements from an automotive domain analysis.
2. We select currently established as well as promising new HTAs for securing our derived use cases for current and emerging automotive architectures.
3. We derive a reference automotive E/E architecture, relevant current and emerging automotive use cases, and a cyberthreat and attacker model from an extensive automotive domain analysis to derive our evaluation criteria.
4. We execute our developed HTA evaluation approach with the derived automotive domain requirements and our selected HTAs and report our findings.
5. In addition to our previous work (Plappert et al., 2022b), we also select and evaluate DICE and SGX as HTAs for very resource-constrained and high-performance ECUs, and extended evaluation criteria for all HTAs.

The remainder of the paper is structured as follows: Section 2 provides an introduction to the automotive domain and the HTAs that will be analyzed later. Moreover, we describe similar related work. Section 3 analyzes the automotive domain, derives a possible future automotive reference architecture, defines a cyberattack and threat model, and presents security-relevant critical use cases. Section 4 derives evaluation criteria from related work and our automotive domain analysis. Section 5 conducts our HTA evaluation approach by analyzing and evaluating various HTAs based on the derived evaluation criteria. Finally, we summarize the results and conclude our work in Section 6. Since we make heavy use of acronyms in the paper, we added a list of acronyms at the end of the paper to ease the reading.

2. Background and related work

This section gives some background on the automotive domain and analyzed technologies. Moreover, it presents related work.

2.1. Automotive domain

Automotive Electrical/Electronic (E/E) architectures evolve constantly and the demand for advanced vehicle services is increasing, e.g., with regards towards increased connectivity or automation. This development is also reflected in the evolution of the vehicle network topologies, which can be clustered by various design principles (Dibaei et al., 2020). Early architectures commonly used a central gateway that interconnects several Controller Area Network (CAN) subnetworks with corresponding Electronic Control Units (ECUs). However, the bandwidth of CAN became a bottleneck for new features due to CAN being a shared medium. Thus, modern vehicles typically employ domain-based architectures that are for example shown in Plappert et al. (2021b). Emerging autonomous vehicles will introduce new performance requirements, causing further adjustments to the network topology. We define a possibly future architecture for autonomous vehicles that we base on Dibaei et al. (2020) in Section 3.

2.2. Trusted computing

To ensure the correctness and integrity of security mechanisms without any tampering, a platform must possess the ability to verify itself and convince remote parties of its trustworthiness. Consequently, it becomes essential to store and process security-critical information in a confidential and tamper-proof manner. To address these challenges, trusted platform and Trusted Computing technologies have been developed.

A trusted platform comprises reliable hardware and software components, offering trustworthy functions such as cryptographic operations, secure storage for security-critical data, and a foundation of trust for software. The primary objectives of a trusted platform are twofold: minimizing the Trusted Computing Base (TCB) and ensuring compatibility

with conventional computing systems. The TCB represents the collective set of system resources (both hardware and software) responsible for maintaining the system's security policy (Trusted Computing Group, 2019b).

The desired properties of a trusted platform can be summarized as follows: 1. Secure storage, which allows the storage of security-critical data on systems that may be inherently insecure. 2. Strong resource isolation to prevent unauthorized access to information by other processes. 3. Secure I/O, facilitating the verification of inputs, outputs, and processes. 4. Integrity determination and verification (attestation), a process involving the measurement of executed software and its subsequent verification by a foreign system. Measuring software integrity is achieved through a simple metric that computes a hash value of binary files, providing verifiable evidence of the system's running software, including boot components and operating system software.

Trusted Computing concepts, relying on hardware roots of trust, have been developed by industry, research, and governmental partners to safeguard computing infrastructure and countless endpoints. The Trusted Computing Group (TCG) is actively involved in the development of various technologies such as the Trusted Platform Module (TPM) and Device Identifier Composition Engine (DICE). Each of these technologies possesses its own cryptographic capabilities, ensuring specific behaviors and protecting systems against unauthorized modifications, malware, and other forms of attacks. Trusted Computing technologies find applications in enterprise systems, storage systems, networks, embedded systems, mobile devices, and can even secure cloud computing and virtualized systems.

The trust model of the TCG is based on trust anchors, which are essential for ensuring trustworthiness as they cannot be manipulated or detected. Certification is employed to guarantee that implementations conform to the specified standards. The TCG defines three types of Root of Trust that are, e.g., implemented by the TPM (Trusted Computing Group, 2019b):

Root of Trust for Storage (RTS) The Root of Trust for Storage (RTS) is responsible for storing measurements related to system integrity. These measurements need to be safeguarded against unauthorized disclosure and manipulation. The TPM separates the RTS from the host system to represent its functionality.

Root of Trust for Measurement (RTM) The Root of Trust for Measurement (RTM) transmits information (measurements) regarding integrity to the RTS. The Core Root of Trust Measurement (CRTM), which is the first code executed during system startup, controls the RTM. The CRTM initiates the measurement chain, known as the Chain of Trust. Typically, the Central Processing Unit (CPU) serves as the CRTM.

Root of Trust for Reporting (RTR) The Root of Trust for Reporting (RTR) reports the contents of the RTS to external components while ensuring the integrity and authenticity of the reported data. The TPM achieves this by signing the data using secret keys known only to the TPM.

2.3. Confidential computing

In most contemporary systems, data is encrypted during storage and transmission over the network, but remains unencrypted in the system's main memory (Confidential Computing Consortium, 2022). Furthermore, the ability to safeguard data and code during usage is limited within traditional computing infrastructures. Confidential Computing (Confidential Computing Consortium, 2022) leverages Trusted Execution Environments (TEEs) to achieve code confidentiality, authenticated launch, and protected and isolated execution of user-defined code (Lear and Tschofenig, 2018). It shares complementary objectives with Trusted Computing, which focuses on load-time integrity verification of all software components in a system. To enable Confidential Computing, Eckel et al. (2023) define an additional Root of Trust (RoT), the Root of Trust for Execution (RTE). We cite their RTE definition in Definition 1. Notably, due to the inherent complexity of implementing an RTE, different implementations may be vulnerable to distinct attacks.

Definition 1 *(Root of trust for execution).* The Root of Trust for Execution (RTE) is a secure and isolated environment in hardware for running custom code separately from the main execution context. This environment relies on the inherent trust placed in the platform's hardware to provide fundamental confidentiality, integrity, and authentication services.

Note 1: The RTE ensures that the code executes undisturbed, even if the underlying platform or operating system is untrusted. Depending on the implementation, the RTE may provide its own Root of Trust for Storage (RTS), Root of Trust for Measurement (RTM), and Root of Trust for Reporting (RTR).

Note 2: The RTE can implement protections against various attacks, including hardware and software side-channel attacks.

Note 3: Typically, the CPU provides RTE capabilities and protections.

2.4. Hardware Trust Anchor (HTA) technologies

State-of-the-art Hardware Trust Anchor (HTA) technologies can be grouped into: (1) dedicated security chips, (2) security subsystems, (3) Trusted Execution Environments (TEEs), and (4) secure bootloaders.

A dedicated security chip is a standalone silicon communicating via a distinct interface with other components. The TPMs or smart cards are examples for this. Security subsystems are characterized by isolated regions on the host system that execute security operations. Examples are the Secure Hardware Extension (SHE) and Hardware Security Modules (HSMs).

Finally, TEEs provide a secure environment for executing code, ensuring high trust for running programs (Felton, 2019). Applications running in a TEE are called Trusted Applications (TAs) and they operate independently of system threats. The TEE coexists with the Rich Execution Environment (REE), such as Linux or Windows. With extensive software usage, the attack surface expands, increasing security vulnerabilities. To mitigate this, the TEE concept was developed, with specifications (GlobalPlatform, 2017, 2021) established by GlobalPlatform (GP), a consortium of stakeholders.

Trust in a TEE encompasses validity, isolation, and access control of stored assets, making Trusted operating system (OS) and TAs within the TEE more reliable. TEE implementations include manufacturer-specific versions tailored to specific needs, and "real" TEE which enable the user to run custom code with strong isolation, enabling enhanced security beyond initial installations. Examples for TEEs are ARM TrustZone (Arm Limited, 2022a) or the Intel Software Guard Extensions (SGX) (Intel Corporation, 2022).

State-of-the-art technologies in the automotive domain are currently the HSM and SHE, while the TPM is just started to be integrated (Infineon Technologies AG, 2019). Vehicle controllers are also increasingly often based on ARM architectures (Infineon Technologies AG, 2020b), hence TrustZone is also becoming a promising HTA to secure future architectures. With more powerful High-Performance Computer (HPC) deployed in the vehicle network, also SGX may be a feasible HTA to secure more advanced services on the powerful vehicle backbone network. Current partnerships between Original Equipment Manufacturers (OEMs) and Mobileye (MAN, 2023; Porsche AG, 2023), an Intel-owned company developing autonomous driving technologies, show that SGX may be indeed used to secure future autonomous driving use cases and is thus relevant to be analyzed in our work. The Device Identifier Composition Engine (DICE) is an instance of a secure bootloader. It establishes a Root of Trust upon which a Chain of Trust (CoT) can be created. Secure Boot works similar to this, with the difference that DICE uses authenticated boot (i.e., manipulations to the boot sequence can

be detected afterward), while Secure Boot uses the secure boot mechanism (i.e., manipulations to the boot sequence cause the boot to abort). DICE is a relatively new technology and currently not deployed in automotive. However, as we show in Section 2.5, some academic work already evaluates its feasibility to secure more resource constrained vehicle components like sensors.

2.4.1. Trusted Platform Module (TPM) 2.0

The TCG has specified the Trusted Platform Module 2.0 (TPM 2.0)[2] and its corresponding software stack in open standards (Trusted Computing Group, 2019b, 2023). The TPM is a security coprocessor featuring some advanced capabilities going beyond typical key management and usage functionality.

It features a True Random Number Generator (TRNG), key generators, engines for symmetric and asymmetric cryptography as well as hash operations, and non-volatile tamper-proof memory. The non-volatile memory may be used to persist keys, monotonic counters, and arbitrary data across boot cycles and can be secured against access by third parties if necessary. For this, it has some advanced access protection mechanisms ranging from simple password-based authorization to session-based authorization using cryptographic keys or complex access policies. The volatile memory can hold currently used keys and session information. Moreover, it contains some exclusive registers for the storage of integrity measurements, the Platform Configuration Registers (PCRs). The PCRs can be used to build a hash chain of measurements as it stores measurement values which only can be extended with new measurements. Based on their value, the PCRs can be used to unlock keys only when in a benign software state (sealing) or securely report the platform state to an external entity (remote attestation) to build a trust relationship.

2.4.2. Device Identifier Composition Engine (DICE)

The Device Identifier Composition Engine (DICE) is a lightweight Root of Trust concept for resource constrained off-the-shelf devices, standardized by the TCG. Contrary to the other solutions, it is a mainly software-only solution with minimal hardware security requirements to enable its implementation on many devices.

It is a bootloader with access to a Unique Device Secret (UDS), a key that represents the device. The UDS must be protected in non-volatile memory so that no other component can access it. The UDS can be used to establish a Chain of Trust based measured boot across different layers, represented by symmetric keys. The firmware-dependent symmetric keys are called Compound Device Identifiers (CDIs) and represent the device identity and the firmware integrity up to the corresponding layer.

As shown in Fig. 1, DICE derives an initial key using the UDS and a measurement of the next firmware component as inputs, resulting in the first CDI (CDI_{L0}). Each following component derives a new CDI from the last one, extending it with the measurement of the next component. Each CDI represents the device identity and the integrity of all firmware executed until then.

The Chain of Trust can be used to enable Sealing and Remote Attestation. Sealing is the encryption of data with a key that is bound to the state of the device. This means that manipulate devices cannot generate the decryption key, so they cannot access the data. Remote Attestation describes a process in which a verifier verifies the trustworthiness of an attester, i.e., that identity and firmware of the attester are as expected. The attester here can be implemented based on DICE, where it provides the foundation to create proofs that device identity and firmware integrity are as expected.

However, due to hardware limitations, DICE can only detect firmware modifications during boot. Moreover, it cannot defend against advanced physical attacks like fault injection. DICE cannot protect its keys against runtime attacks, so keys available during the runtime of the device may be leaked to runtime attackers (Hristozov et al., 2022), which could cause permanent compromise. Here, the security depends on the security level of the application. Countermeasures can be an application written in a memory-safe language like Rust and the deletion of attestation keys after their usage.

[2] For brevity in the following simply referred to as TPM.

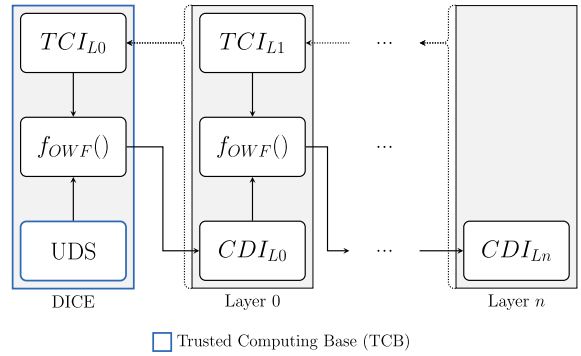

Fig. 1. DICE architecture.

2.4.3. Arm TrustZone

Arm licenses processor designs and groups their newer Cortex processors in three categories based on application spaces: High-end application processors (Cortex-A), high-performance real-time processors (Cortex-R) and resource constrained microcontroller processors (Cortex-M).

The Arm TrustZone (Arm Limited, 2022a,b) is a security extension available to some Cortex-A and Cortex-M processors, as a low-cost alternative to adding a dedicated security core to a System on Chip (SOC). TrustZone enables processors to switch between two states, the secure and non-secure world, using a hardware-backed access control mechanism. The switching mechanism is orthogonal to all other capabilities of the processor and each core can operate independently of the user while using the same core. Memory and peripherals are made aware of the current operating world. The non-secure world is intended for normal applications, while the secure world is intended for security-sensitive software components (secure boot, cryptographic libraries, authentication) and security resources (e.g., secure storage, cryptographic accelerators, random number generators). Resources of the non-secure world are available to both worlds, while resources of the secure world are exclusive for it.

2.4.4. Intel Software Guard Extensions (SGX)

The hierarchical protection rings implemented by the CPU offer a level of security by protecting the OS from applications and ensuring isolation among applications. However, these protection mechanisms do not safeguard applications against attacks from privileged code. A malicious application can exploit vulnerabilities in the OS kernel and gain unauthorized access through privileged code. Intel SGX (Intel Corporation, 2022) aims to address these challenges with the following objectives:

1. Enabling applications to defend their own secrets
2. Minimizing the attack surface by restricting it to application components and the CPU
3. Eliminating the need for a separate processor

Intel SGX introduces CPU instructions as an extension, primarily with the Intel Skylake processors. At the core of SGX lies the concept of an “enclave”, which provides a protected environment to contain the code and data of security-sensitive computations. Multiple enclaves can coexist within a system, distinguishing SGX from Arm TrustZone, which has only one trusted world. Enclaves are isolated from untrusted software, including the OS, as well as from other enclaves.

SGX offers support for remote attestation, a process where an enclave proves its existence on a genuine Intel SGX-enabled processor and verifies the loaded software code. Remote attestation in SGX facilitates the establishment of an authenticated secure channel, enabling secure transfer of secrets into the enclave.

SGX enclaves are stateless, meaning all information within an enclave is lost upon destruction. However, SGX provides data sealing capabilities to store encrypted application data and state outside the enclave. The enclave encrypts the data using a sealing key, and it is subsequently stored externally, such as on a hard drive. The sealing key is derived from the CPU and can be based on either the hash of the current enclave or the hash of the enclave's signature. The latter allows data sharing between enclaves that are signed with the same key. Notably, all SGX enclaves must be signed. Sealed data can only be decrypted (unsealed) on the same system or CPU. This sealing mechanism provides confidentiality, integrity, and authenticity for the stored data.

Trust Domain Extensions (TDX) (Intel Corporation, 2023a), Intel's next-generation technology, addresses some of SGX's limitations. Unlike SGX, which secures selected parts of an application, TDX offers a more comprehensive solution by making an entire virtual machine a secure enclave. It leans into virtualization-based security, thereby expanding the scope of applications that can be securely run, especially legacy software. Consequently, TDX proves more flexible, although at the expense of some performance overhead due to the comprehensive virtual machine-based security. Both technologies use hardware and firmware-level protections and offer remote attestation capabilities, yet they differ fundamentally in scope and implementation. While SGX can be more performant, TDX provides a less restricted and more versatile environment for software applications. With Intel phasing out SGX support in favor of TDX in its new processors, TDX could be considered an evolutionary step or even a superset of SGX, given it adopts and extends many features of its predecessor. As TDX continues to integrate into platforms—evidenced by its support in the Linux v5.19 kernel (Linux Kernel Newbies, 2022; The kernel development community, 2023a,b)—it is positioned to provide a more accommodating and robust confidential computing environment. Therefore, in the evolving sphere of confidential computing, TDX seems to be the technology that Intel is positioning for long-term viability and broad-based application.

It is important to acknowledge the existence of several other TEE or TEE-like technologies, including RISC-V MultiZone (Hex Five Security, Inc., 2023) and Keystone (Keystone Enclave, 2021), IBM Secure Service Container (Roscher et al., 2018), AMD Secure Encrypted Virtualization (SEV) (Advanced Micro Devices, Inc., 2023), Intel TDX, and others. Each of these technologies offers a distinct set of features or serves specific purposes. For instance, AMD's SEV is specifically designed for virtualized systems and cloud appliances. Many of these technologies also provide similar functionalities to Intel SGX. However, it is essential to recognize that each of these technologies has its own limitations. In this paper, we utilize SGX as a representative example of these TEE implementations.

2.4.5. Secure Hardware Extension (SHE)

The German OEM software initiative (HIS, German for "Herstellerinitiative Software") has specified the SHE, an on-chip security extension for Microcontroller Units (MCUs). HIS, a committee drawn from Audi AG, BMW AG, Daimler AG, Porsche AG, and Volkswagen AG, tries to define harmonized interfaces (product and process) to reduce supplier effort to adapt to differing OEM requirements.

SHE uses a hardware-backed shielded location to isolate cryptographic keys from the rest of the controller, securing them against various attacks. SHE provides a lower level of security than other high security solutions like TPMs or smart cards since the specification, among other things, does not require SHE to be resilient against physical attacks. Three components are part of SHE: Memory for storing cryptographic keys and their metadata, cryptographic engines, e.g., to implement block ciphers like AES, and control logic that connects SHE to the CPU of the controller. SHE can be implemented as state machine or as part of a small, dedicated CPU core. Manufacturer-specific enhancements of the basic specification are labeled as SHE+.

2.4.6. EVITA Hardware Security Module (HSM)

Representatives of the automotive industry and academic research partners have defined three different variants of HSMs for the application in the automotive environment (Evita Consortium, 2011) during the research project EVITA (Evita Consortium, 2008): EVITA *full*, *medium* and *light* HSMs that offer different capabilities for various application scenarios. EVITA *full* is intended for Vehicle-to-Everything (V2X) scenarios where strong performance requirements for signature generation and verification have to be met. EVITA *medium* is intended to be used for in-vehicle ECU communication. EVITA *light* can be used for sensor/actuator communication. The EVITA HSM features a shielded location and, similar to the TPM PCRs, ECU Configuration Registers (ECRs) that enable trusted computing concepts like sealing and remote attestation.

2.5. Related work

HTAs in the automotive sector previously have been the topic of some other publications. In Wolf and Gendrullis (2012), the authors propose a vehicular HSM for the protection of in-vehicle ECUs and their communications. They provide a description of their hardware design, details on their prototypical implementation as well as a performance evaluation. Also, they compare their HSM to other already existing HTA solutions. In Hu and Luo (2018), the authors evaluate secure communication approaches for vehicular networks and among others also introduce SHE, the EVITA HSM and the TPM. They also include performance measurements of AES-128 encryption for the HSM of an NXP MPC5748G. Wu et al. (2019) provide an analysis of different in-vehicle key management systems and shortly compares the EVITA HSM and the TPM regarding their costs, provided security and functionality. A whitepaper by NXP (NXP Semiconductors, 2020) describes concepts and usage paradigms of security subsystems, with security subsystems being defined as central or distributed security components integrated within a larger Integrated Circuit (IC).

In their work (Zelle et al., 2020), Zelle et al. describe DICE, TPM, TrustZone, and SGX as suitable mitigation technologies to secure the vehicle against a variety of already successfully exploited automotive vulnerabilities. Moreover in Plappert et al. (2022a), Plappert et al. design TPM- and DICE-based automotive security patterns that can be used as generic blueprints to apply to instantiated E/E architectures and improve their security according to different use cases. The work is extended in Fenzl et al. (2023) where the DICE and the TPM-based integrity and attestation concepts are extended with a TPM-based role and rights management pattern for secure automotive access and remote feature activation.

The analysis of related work indicates that a comprehensive analysis of automotive HTAs is quite rare. Existing work is either quite old (Wolf and Gendrullis, 2012) and does not consider current developments, analyze the topic from a more generic level (Hu and Luo, 2018; Wu et al., 2019), or focus on one specific HTA (NXP Semiconductors, 2020). However, we use the contents of related work to derive some of our evaluation criteria and if necessary update their evaluation results with current developments.

3. Automotive domain analysis

In this section, we analyze requirements and properties of the automotive domain. This includes the definition of a current automotive E/E reference architecture, a threat model and attacker model, and prominent automotive use cases.

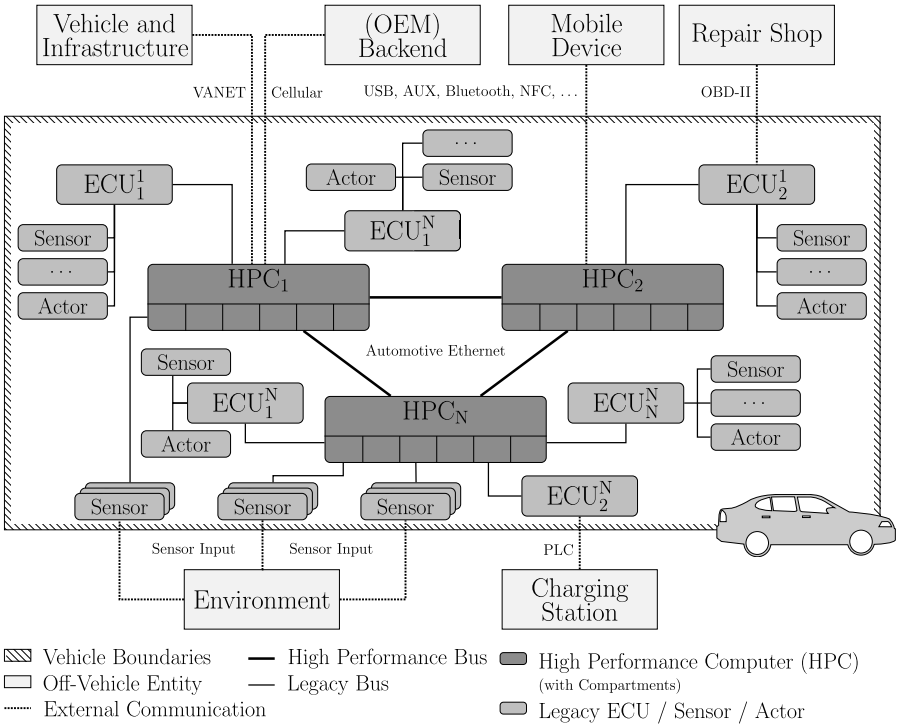

Fig. 2. Reference design of a possible upcoming automotive E / E architecture.

3.1. Automotive reference architecture

With the current trend towards connectivity and automation, in-vehicle networks are constantly evolving to meet new performance requirements. Fig. 2 shows our future E / E reference architecture that we derive from current developments and design principles that were introduced in Section 2.

This architecture is dominated by a high-throughput backbone network. It consists of interconnected HPCs that are connected via high-throughput network technology, e.g., Automotive Ethernet. The backbone network is designed to meet high-performance and safety requirements from automation from the developments towards automation and connectivity. The HPCs offer vast computing capacities and can be utilized to implement redundancy and virtualization concepts. This high-performance backbone network is connected to the more resource constrained "legacy" subnetworks that feature smaller ECUs, sensors and actors as well as some traditional network technology, e.g., CAN. Depending on the system requirements, sensors and actors can also be directly connected to the HPCs to meet high-performance requirements that are for example needed for processing autonomous driving tasks.

3.2. Automotive threat and attacker model

The reference architecture described in the previous section, shows that modern vehicles are increasingly connected both internally and with external entities through diverse interfaces and technologies. The resulting increasing complexity both in connectivity and regarding the amount of used software, further broadens the cyberattack surface. This concerns both remote cyberattacks via external entities connected via long-range communication technologies like cellular networks or physically connected entities like repair shops, mobile devices, or charging stations that themselves are exposed, e.g., via Internet, to other remote parties. In addition, the components of the vehicles are physically exposed and thus vulnerable against side channel or (semi-) invasive tampering attacks, e.g., timing or microprobing attacks.

According to this analysis, we define the following three attacker types: The communication channel attacker (Type1), the hijacking attacker (Type2), and the physical attacker (Type3). The attacker types have increasing capabilities while, as our previous work has shown (Plappert et al., 2021b), decreasing attack feasibility.

We align the Type1 attacker with the classic Dolev-Yao attacker (Dolev and Yao, 1981). This attacker type can access the internal and external connections of the vehicle. With this access, the attacker can eavesdrop, replay, inject, relay, modify, and/or intercept all transmitted messages. However, the attacker cannot break any cryptography that may be used to secure the communication.

In addition to the Type1 attacker, the Type2 attacker can hijack ECUs to circumvent software security mechanisms, e.g., access control, with privilege escalation attacks.

Finally, our Type3 attacker is aligned to the cyberphysical Dolev-Yao attacker (Rocchetto and Tippenhauer, 2016). This attacker type is additionally capable to tamper with the hardware mechanisms. The attacker may execute side channel attacks, e.g., electromagnetic, timing or differential power analysis, read, modify or delete security-sensitive memory.

This attacker model is later used to evaluate the analyzed HTAs according to their provided security guarantees.

3.3. Automotive use cases

The work of Ring et al. (2018) details about current automotive security trends. They claim that by 2023, currently seldom used security mechanisms like secure external and internal communications, secure and authenticated boot, signed software updates, HTAs, and the use of Public Key Infrastructures (PKIs), will be common in many automotive E / E architectures.

Thus, we now define corresponding automotive use case that make use of these mechanisms. We will later align our HTA evaluation criteria to these use cases to show the relevance of HTA features in relation to the requirements in the automotive domain. Our use cases are UC1: Credential Management, UC2: ECU Communication, and UC3: HPC Utilization.

3.3.1. UC1: credential management

As our reference architecture in Fig. 2 shows, the vehicle network is complex. To deploy security mechanisms, the components must be

equipped with credentials like Universally Unique Identifiers (UUIDs) like serial numbers, cryptographic keys and/or certificates. These credentials must be securely distributed and stored on the corresponding ECUs but also securely announced to the relevant communication endpoints to establish trustworthy communication channels. In particular, ECUs must be initialized with credentials if not already done during the manufacturing process. This can either be done with key creation or derivation mechanisms. Afterwards, the necessary parts of the established credentials need to be exchanged among the relevant in-vehicle ECUs or announced to remote parties in the environment of the vehicle, e.g., charging stations, repair shops, OEM backend systems, or in case of V2X to other vehicles or road side units. This will then enable mutual trust relationships between all entities and is the prerequisite for the security concepts of all following use cases.

A secure update mechanism for the established credentials is crucial for the overall security concept to constantly mitigate against upcoming vulnerabilities. For example, this concerns the renewal of expired certificates, leaked keys, or even cryptographic primitives and schemes. A secure update mechanism is especially crucial with vehicle life cycles of more than 20 years (Evita Consortium, 2011).

3.3.2. UC2: ECU communication

With the increasing exchange of safety- and security-sensitive data between both the in-vehicle entities and to entities in the vehicle environment, the security of all communication channels is becoming more and more crucial to enable new services like V2X or autonomous driving.

The establishment of trust is typically done with the use of cryptography, e.g., by encrypting or authenticating exchanged messages. However, in current architectures the use of cryptographic schemes is mostly limited to major ECUs and often limited to message authentication using symmetric Message Authentication Codes (MACs) like the Automotive Open System Architecture (AUTOSAR) Secure Onboard Communication (SecOC) standard. This is due to current limitations in bandwidth and processing power in the in-vehicle network.

With the current development towards connectivity and automation, the need for secure communication is increased while also the capabilities of the internal components will rise. This enables to deploy more resource-intense but easy to manage cryptographic schemes like asymmetric cryptography, which enables more security-proof standards, e.g., Transport Layer Security (TLS), or also the use of encryption mechanisms to enable new services.

3.3.3. UC3: HPC utilization

With the current trend towards full automation and the corresponding use cases like autonomous driving or ride-sharing scenarios, performance improvements of the internal network technologies and ECUs become necessary. This use case is especially targeted at upcoming use cases and challenges that will utilize the increased performance and capabilities of the high-performance backbone network and connected HPCs. Examples are the secure consolidation and virtualization concepts of Virtual ECUs (vECUs) on one or multiple HPCs and the corresponding safety and redundancy concepts.

4. Evaluation criteria definition

We derived evaluation criteria from our automotive domain analysis as well as from related work, resulting in the following list: EC1: Security Services, EC2: Platform Security, EC3: Flexibility, EC4: Performance, EC5: Software Ecosystem, EC6: Cost Efficiency, and EC7: Hardware Integration. These will be detailed in the following sections.

4.1. EC1: security services

Security services provide the actual functionality to the host environment. They can be used to achieve the confidentiality, integrity, and authenticity of data. We cluster them into 1. auxiliary, 2. basic, and 3. advanced services.

4.1.1. Auxiliary security services

Auxiliary security services provide the foundation for basic or advanced services and can be used to implement higher-level security concepts. They must be implemented in hardware as they cannot be emulated in software with the same security guarantees.

Non-Volatile Memory (NVM): Non-volatile memory can be used to store arbitrary information as well as specific access protected data structures like monotonic counters or bit fields. Possible uses for this service include storing public information like certificates or public keys integrity-protected or defining obligations based on status of counters or bit fields.

Secure Internal Clock (SIC): This service enables a hardware-protected time reference that may be synchronized with UTC time.

Random Number Generator (RNG): Many cryptographic operations, like nonce generation or secret key generation, rely on strong Random Number Generators (RNGs). Typically, Pseudo Random Number Generators (PRNGs) are seeded internally from a TRNGs or externally from a TRNG during production.

4.1.2. Basic security services

These services provide basic security functionality from cryptographic engines to key management.

Asymmetric Cryptographic Engines (ACE): This service enables the usage of asymmetric cryptography, including creation and verification of digital signatures as well as data en- or decryption.

Symmetric Cryptographic Engines (SCE): This service enables secret key-based data encryption and decryption. Usually, this is based on a block cipher like Advanced Encryption Standard (AES) and a selection for encryption modes for it.

Message Authentication Codes (MAC): This service enables the generation and verification of MACs that get created using a secret key. Typically, implementations are based on Hash-based Message Authentication Code (HMAC) or Cipher-based Message Authentication Code (CMAC).

Key usage: This service can be used to bind key usage to various obligations. Examples for this include usage restrictions, like digital signature generation and verification, MAC generation and verification, encryption and decryption, or usage authorization mechanisms like simple password protection, session-based authorization, or platform sealing.

Key management: This service allows managing cryptographic keys securely. This includes key creation, key agreement (e.g., Diffie-Hellman), key derivation as well as key import from and export to trusted external parties.

4.1.3. Advanced security services

These services can be used to extend basic key management and usage functionalities. They are relevant for more advanced use cases.

Secure and measured boot: This service can be used to ensure the integrity of the system. In the case of secure boot, software images are verified, e.g., using digital signatures, before their execution. Unsuccessful verification typically results in the boot process being stopped. For measured boot, the going-to-be executed code is measured (hashed) before handing over control. The measurements are securely stored in a RTS, e.g., TPM, or are used as input to a Chain of Trust that gets initiated by an RTM, e.g., DICE, and can be reported to external entities. Secure and measured boot are orthogonal security mechanisms, where secure boot ensures the execution of a benign software, and measured boot ensures the execution of the correct software.

Attestation: This service allows a system to prove its trustworthiness, e.g., its integrity, to a third party, called the verifier. This is usually done by sending authenticated values obtained from the measured boot to the remote verifier.

Audit: The audit service allows an (external) auditor to trace that operations were successfully executed within the HTA.

Hardware Watchdog Timer (HWDT): A HWDT is a privileged component that may trigger safety mitigations of the subcomponent, e.g., fail-safe modes, in case a periodically triggered challenge-response mechanism fails, e.g., because of denial-of-service attacks.

Isolated execution: This service can be used to execute custom code in a protected environment, the TEE, using an RTE. Typically, it is possible to perform an attestation of the code loaded into the TEE to prove its integrity to a relying party.

4.2. EC2: platform security

The main advantage of all HTA technologies is the provided shielded location. It protects security-sensitive data from unauthorized access and in some cases also against physical tampering, depending on the specific HTA.

The platform security evaluation criterion evaluates the security guarantees of the provided shielded location of the analyzed HTAs against our defined attacker model. The evaluation includes the tamper-resistance properties against physical attacks, the general security properties and an analysis of the provided TCB for each HTA. The tamper-resistance properties are evaluated base on present tampering protection mechanisms. Since these are usually black-box mechanisms, their evaluation must be based on mere presence or absence. Since tampering protection features are not mandatory for many HTAs, the mere presence of them can be regarded as a benefit to the security against attacks.

For the evaluation of the general security properties, we analyze the architecture of each HTA holistically and from a high-level point of view. We rate an HTA that is implemented as a discrete chip and connected to the CPU with a peripheral bus higher than an HTA that is integrated into the same package as the main CPU due to the stronger hardware isolation. Integrated HTAs are rated higher than those that use on-chip resources of the main CPU. We also regard HTA with a Common Criteria certification as more secure because its implementation is externally verified and reviewed.

The TCB is the foundation of a system, consisting of a minimal set of hardware and software components, that must be trusted as uncompromised to fulfill the system security guarantees. Generally, a smaller TCB results in a higher security level. Also, less exposed interfaces to the main CPU correspond with a higher security level.

4.3. EC3: flexibility

This evaluation criterion evaluates the usage flexibility of the corresponding HTA. Flexibility refers to both the ability to adapt the HTA to implement necessary features to support use cases and the mitigation of upcoming attacks through crypto-agility. In the automotive context, the latter is particularly important due to long lifecycles of vehicles in the field with over 20 years (Evita Consortium, 2011).

We regard a fully programmable HTA as the most flexible solution because it can provide all functionality that can be implemented on it. For HTAs with a fixed feature set, a larger feature set results in a better flexibility rating.

Cryptoagility is evaluated based on the HTA supporting arbitrary cryptographic algorithms. Freely programmable HTAs are again the most flexible. HTAs where the feature set can be expanded (e.g., by installing updates) receive a higher flexibility rating than those where the feature set cannot be expanded. The presence of hardware accelerators and features increases the rating for flexibility.

4.4. EC4: performance

Some automotive use cases, e.g., V2X message exchanges (Bottinelli and Lambert, 2019), require a high-performance throughput of cryptographic operations. With this evaluation criterion, we compare the relative performance of each analyzed HTA regarding its processing power and possibly available cryptographic hardware accelerators. Typically, integrated solutions achieve a higher performance than discrete chip solutions due to limitations of the peripheral bus system. Integrated solutions are generally faster with hardware accelerated integrated solution having an advantage over those that do not feature hardware acceleration.

Table 1
Dependency of evaluation criteria from the automotive analysis.

	EC1	EC2	EC3	EC4	EC5	EC6	EC7
Use Case	●		●	●			
Attacker Model	●	●	●				
Automotive Domain					●	●	●

4.5. EC5: software ecosystem

This criterion analyzes the available software for an HTA technology. This involves firmware, drivers, software stack and application software, but also looks at software licenses and potential associated additional costs. An HTA with an existing and thriving software ecosystem scores better than one where much of the software needs to be implemented. For an existing ecosystem, we give the lowest score to proprietary software because open-source software is more easily available and less expensive. Open-source software with a permissive license scores better than open-source software with a copyleft license because of its higher flexibility regarding business models.

4.6. EC6: cost efficiency

The cost efficiency criterion covers additional costs that incur when integrating an HTA into a system. The costs depend on two factors 1. the cost of required hardware for the HTA 2. the cost of the software and 3. the readiness of the software. Thus, this criterion partially overlaps with EC5. Lower costs are rated better than higher costs.

4.7. EC7: hardware integration

The hardware integration criterion is concerned with the cost and flexibility of integrating the hardware required for the HTA in an existing system. A discrete chip HTA for example is more difficult to include than an HTA that is integrated into the main CPU because it requires space on the PCB and a free peripheral bus to the CPU. Furthermore, the criterion includes the energy consumption of the hardware as this also can be a disqualifying factor for especially the low-powered legacy ECUs used in the automotive context. Discrete chip HTAs typically score worse under this aspect too because they include their own CPU and bus drivers that need to be supplied with energy instead of using the corresponding resources in the main CPU.

5. Hardware Trust Anchor evaluation

We evaluate the HTAs in this section based on our defined evaluation criteria and some insights from our analysis of the automotive domain. This evaluation is based on the specifications of the following HTAs: Escherich et al. (2009) for SHE, Wolf and Gendrullis (2012); Evita Consortium (2011) for EVITA, Trusted Computing Group (2019b) for the TPM, Trusted Computing Group (2018b, 2020) for DICE, Arm Limited (2022c, 2023) for TrustZone, and Intel Corporation (2023b, 2022) for SGX.

The dependency of evaluation criteria from aspects of our analysis of the automotive domain regarding our assessment is shown in Table 1. Each criterion is described in detail in the following subsections, and we summarize our findings in Section 6.

Table 2
Security services comparison.

HTA	Auxiliary Services			Basic Services					Advanced Services
	NVM	ICL	RNG	ACE	SCE	MAC	KUS	KMA	
SHE	keyslot	–	PRNG (TRNG seed)	–	AES-128 ECB/ CBC	CMAC	enc, MAC	export (RAM key only), import	Secure Boot
EVITA *light*	(arbitrary, counter)[1]	ext. UTC	AES-PRNG (ext. Seed)	–	AES-128 CCM/ GCM	CMAC	encr., authentication, derivation, authorization (PW, integrity)	creation, derivation, exchange, import, export	(Secure & Measured Boot)[1] [Auditing, Attestation][2]
EVITA *medium*	arbitrary, counter	ext. UTC	AES-PRNG (TRNG seed)	ECC-256	cf. EVITA *light*	cf. EVITA *light*	cf. EVITA *light*, DH	cf. EVITA *medium*	Secure & Measured Boot [, Auditing, Attestation][2]
EVITA *full*	arbitrary, counter	ext. UTC	AES-PRNG (TRNG seed)	cf. EVITA *medium*	cf. EVITA *medium*	CMAC, HMAC	cf. EVITA *medium*	cf. EVITA *light*	Secure & Measured Boot [, Auditing, Attestation][2]
TPM 2.0	arbitrary, monotonic counter, bitfield, extend, pin	secure time	TRNG	RSA, ECC	(AES)	HMAC, CMAC	encr., authentication, derivation, DH, transport, authorization (pw, Session (key, policy))	creation, derivation, exchange, import, export, duplication, certify creation	Measured Boot, Attestation (Root of Trust for Reporting, Quote Command), Audit Sessions, HWDT
HSM (no FW)	–[3]	–[3]	–[3]	FP	FP	FP	FP	FP	FP
TrustZone	–[3]	–[3]	–[3]	FP	FP	FP	FP	FP	FP
DICE	–[3] (sealed memory)	–[3]	–[3]	FP	FP	FP	FP	FP	Measured Boot, Attestation
SGX	arbitrary (encrypted in file system)	UTC clock	TRNG	FP	FP	FP	FP	FP	Attestation, Isolated Execution

[1] Optional, [2] Soft Requirement, [3] HW requirement and cannot be realized by software, ACE: Asymmetric Cryptographic Engine, CHF: Cryptographic Hash Function, FW: Firmware, FP: Freely Programmable, HWDT: Hardware Watchdog Timer, KMA: Key Management, KUS: Key Usage, NVM: Non-Volatile memory, RNG: Random Number Generator, SCE: Symmetric Cryptographic Engine, ICL: Internal Clock.

5.1. Security services

An overview of the security services that the respective HTAs provide is given in Table 2. The table orders the HTAs by the range of security services that they offer. The HTAs can be roughly clustered into HTAs with a (fixed) feature set (SHE, EVITA HSMs, and TPM) and HTAs that are freely programmable (HSMs without firmware, TrustZone, DICE, and SGX). The latter HTAs then may offer all services that can be implemented in software. To some extent, DICE can also be the foundation of a freely programmable security solution. The security guarantees that such a solution can provide are however not as strong due to a lack of hardware isolation. For all freely programmable solutions the availability of features that depend on specific hardware such as Non-Volatile memory (NVM), Internal Clock (ICL), TRNG or a HWDT is dependent on the specific implementation.

Among the HTAs that are designed with a fixed feature set, SHE and EVITA *light* represent a class of lightweight HTA. Consequently, they provide the most limited set of security services. The most important limiting factors are the absence of asymmetric cryptography and an ICL. SHE provides a TRNG that is used to seed the PRNG. Its NVM, however, can only be used as a key slot or to store a MAC for secure boot. SHE furthermore provides CMAC. In EVITA *light*, the NVM is considered optional as well as support for secure or measured boot. It provides a PRNG that must be seeded by an external TRNG and supports more secure modes of encryption for AES than SHE and more fine-grained mechanisms for key usage such as key authorization.

EVITA *medium* and EVITA *full* extend the feature set of EVITA *light*. They add the requirement of a mandatory NVM and means for boot time integrity protection based on secure or measured boot as well as an ICL, support for HMAC and an internal TRNG that is used to seed the PRNG. In addition to these features, EVITA *full* furthermore is required to provide a hardware engine for Elliptic Curve Cryptography (ECC)-based asymmetric cryptography. No hard requirements are given for advanced security services such as auditing or remote attestation.

The TPM provides the most extensive feature set of all the examined HTAs. Most of these features are compliant with the security services that other HTAs provide. The TPM does, however, add or enhance some features. The NVM, for example, can store arbitrary data as well as pre-defined data types such as bit fields, monotonic counters, “extend” fields that store integrity measurements and PIN fields that can be used to protect data against dictionary attacks. However, in typical hardware implementations the TPM’s NVM is very limited (e.g., 6962 Bytes, Infineon Technologies AG 2022). The TPM also provides means for secure or measured boot, such as the PCRs, and can be used as an RTR. In this role, the measured boot can be combined with trustworthy remote attestation techniques. The correct execution of a set of commands can be verified over a remote channel using the audit feature.

Table 3 shows in an abstract fashion which use case requires the availability of which security service and consequently, which HTAs are suited to fulfill these requirements.

In UC1: Credential Management many operations that concern key management (generation, derivation, exchange, storage, and usage) are used to create credentials and securely distribute them during the provisioning process and afterwards if an update or revocation of outdated credentials are necessary. Remote attestation techniques can be added to verify the integrity of a system before interacting with it on this key management level. This is dependent on the specific implementation. If

Table 3
Mapping Security Services (SS) to Use Cases (UC) and HTAs.

Security Service (SS)	Use Case (UC)			HTA						
	UC1	UC2	UC3	SHE	HSM (EVITA)	TPM	HSM (no FW)	TZ[1]	DICE	SGX
Key Generation/Update	✓	(✓)	(✓)	○	●	●	(●)	(●)	(●)	(●)
Secure Storage Flexibility	✓	-	(✓)	◐	●	●	(●)	(●)	(●)	●
Key Usage Authorization	✓	✓	✓	○	◐	●	(●)	(●)	(●)	(●)
Key Backup	-	-	✓	○	●	●	(●)	(●)	○	(●)
Concurrent Access	-	-	✓	○	◐	●	●	●	○	●
Attestation	(✓)	✓	✓	○	◐	●	(●)	(●)	(●)	●
Secure Timing	-	✓	✓	○	●	●	◐[2]	○	○	●
HW Watchdog Timer	-	-	✓	○	○	●	◐[2]	○	○	○
Audit	(✓)	-	✓	○	◐	●	(●)	(●)	○	(●)

UC1: Credential Management, UC2: ECU Communication, UC3: HPC Utilization, ✓: SS primarily used in UC, -: SS typically not relevant in UC, (✓): SS may be relevant in UC, [1] TrustZone, [2] Hardware feature that depends on host controller, (●): Implementation specific.

available, audit sessions can be used to gain trustworthy evidence that the key management commands were executed correctly.

UC2: ECU Communication requires no key management operations except for the optional exchange or derivation of session keys. The focus is on services that use the keys. When the ECUs of the vehicle communicate with backend systems, attestations of the firmware integrity are important to allow the backend an assessment of their trustworthiness before establishing the communication channel. The secure synchronization of time between the ECUs is especially important for the exchange of messages between the vehicle and its environment and features that are limited in its execution time frame like feature activation.

UC3: HPC Utilization is a use case that includes all security services. In addition to the services provided by the other use cases, UC3: HPC Utilization also includes key backup, concurrent access and HWDTs. These services address future challenges in security, especially considering the consolidation of vECUs on a unified platform and the required redundancy and safety concepts.

The use case mapping in Table 3 shows that the TPM, EVITA, the freely programmable HSMs, the TrustZone, DICE, and SGX provide support for key generation, both based on Diffie–Hellman (DH) key exchange protocols and with key derivation functions. The TPM also provides a certification process that can be used to securely prove to a remote verifier that a key was created by the TPM. This feature can be used to secure the key update process. SHE does not provide a mechanism to generate keys. It does, however, feature a key update protocol that can be used to import new keys over a secure remote channel. In all HTAs the usage of the keys can be restricted to a certain purpose (e.g., encryption or authentication) with a flag mechanism.

The most important reason to include an HTA in an automotive ECU is the use as a secure storage for sensitive keys. Consequently, every analyzed HTA provides means to store keys securely with a different scope of functionality and nature of the stored data. Most notably, SHE can only store keys and a MAC for secure boot in its NVM. The security guarantees given by HTAs are different and dependent on the implementation. DICE for example protects sensitive key material using sealing, which provides a lower level of security than a TPM that provides hardware isolation and tamper protection mechanisms to protect its memory. Similarly, SGX can securely generate keys inside an enclave and store them outside, e.g., in the file system, encrypted with a key only known to the particular enclave.

In addition to the key flags that specify the purpose of the key and that are defined during key provisioning or update, it may be necessary to protect the keys with an authorization mechanism. SHE provides such a mechanism only for its key update protocol. No authorization is provided for the usage of the key. EVITA HSMs support key authorizations based on passwords, sealing, or a combination of both. In DICE-based solutions, an authorization mechanism can be implemented based on sealing. The freely programmable HTAs TrustZone, SGX, and HSM can provide any mechanism depending on the implementation. The TPM provides the Enhanced Authorization (EA) feature that can be applied to all data stored in it. This mechanism can provide simple password-based authorization as well as session-based authorizations. These session-based authorizations are designed for remote usage over insecure channels using either challenge-response schemes based on, e.g., an HMAC, or fine-grained TPM policies. These polices allow to bind the key to a number of conditions like the state of the platform, a certain time frame, the usage with a limited set of TPM commands or knowledge of a certain cryptographic key. This feature can be used to implement complex role and right management systems completely inside the TPM (Plappert et al., 2021a).

Key backup is a security service that is mostly used to provide redundancy, e.g., to fulfill the safety requirements necessary for autonomous driving. The freely programmable HTAs TrustZone, SGX, and HSM as well as the TPM and EVITA HSMs provide fine-grained solutions that enable key backup. With EVITA HSMs and the TPM, keys can be marked as not migratable at all, migratable to entities with the same trustworthiness level (e.g., another HSM or TPM) or migratable to any other entity. SHE provides a mechanism to export the Random-Access Memory (RAM) key but only with the secret key that is unique for the device. Consequently, it cannot be used as a backup mechanism because the exported key can only be decrypted by the same entity.

Concurrent access is an important security service for future use cases like the virtualization of ECUs. Since virtual machines in general, and virtualized ECUs in particular, share the same resources of the underlying hardware platform, it is paramount to provide concurrent access to data stored in HTAs. Concurrent access involves integrating features such as authentication and access control that facilitate securing data against unauthorized access by imposing credentials and policies. These are key contributors to domain isolation and multi-user isolation, creating comprehensive protection mechanisms. The TPM and EVITA HSMs provide concurrent access by via a session mechanism. The EVITA specification, however, only makes general assumptions such that sessions must be feasible without defining or requiring them. SHE module currently lacks provisions for concurrent access, whereas TrustZone exhibits robust support in this regard. Notably, scholarly endeavors have been undertaken to augment TrustZone's capabilities, extending its scope to encompass parallel execution paradigms (Li et al., 2020). Intel SGX presents a distinct paradigm by enabling concurrent—and even parallel—execution of a virtually unbounded multitude of enclaves.

Remote attestation is prominently featured by the TPM which is designed to act as an RTS as well as an RTR. In its role as an RTS it stores integrity measurements securely in a PCR. These PCRs can then be used with the `TPM2_Quote` command which is used to report the integrity measurements securely to a remote verifier. A number of standards for remote attestation mechanisms exist (RATS Working Group, 2020; Fuchs et al., 2022). The EVITA HSMs provide ECRs with a similar

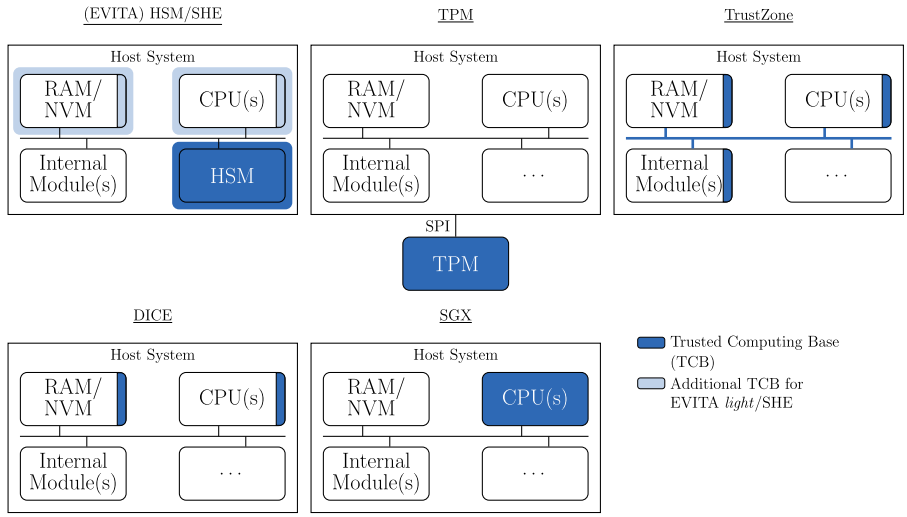

Fig. 3. TCB comparison of the analyzed HTAs.

functionality to PCRs. They can also be used to store integrity measurements but unlike the TPM, EVITA HSMs do not provide a command for integrity reporting or a protocol for remote attestation. SGX remote attestation can be leveraged to ensure a particular software is running in an enclave. In contrast to TPM remote attestation, which is used to attest whole systems including all executed software, SGX remote attestation is used for single applications. It is noteworthy that SGX can start and execute (enclave-based) applications in a trustworthy manner, even if the OS is compromised.

The security services of secure timing and the HWDT need to be implemented in hardware. Consequently, neither TrustZone nor SGX or the freely programmable HSM provide them. The TPM and the EVITA HSMs both feature an ICL that can be synchronized to Universal Time Coordinated (UTC). This enables use cases based on time such as temporary access to the vehicle for car sharing (Plappert et al., 2021a). The TPM also exclusively provides a HWDT. This feature allows the implementation of safety concepts for autonomous vehicles such as hot-cold fail-over concepts (Isermann et al., 2002). SHE does not provide any of these security services.

The audit security service provides the means to verify the successful and correct execution of commands. This is especially helpful during remote provisioning of HTAs. SHE does not provide this feature. It can be implemented in the freely programmable HSMs, SGX, and TrustZone. The EVITA HSMs have a soft requirement for an audit feature for certain important commands, command invocation failures and internal errors. However, this is neither detailed nor specified. DICE can be extended with additional hardware to provide this feature. Academic work exists on this topic (Xu et al., 2019; Huber et al., 2020), but this requires the presence of an Authenticated Watchdog Timer (AWDT) or a TrustZone.

5.2. Platform security

We assess the security of each of the examined HTAs based on evaluation criteria such as tamper-resistance, the scope of the TCB rooted in it and verifiability of its specification regarding the attacker model we defined earlier. The comparison of the structures of the HTAs shown in Fig. 3 is adapted from Plappert et al. (2022b). It shows the general structure of the analyzed HTAs in relation to their respective TCB.

The TPM is a discrete coprocessor for security use cases. It is connected to the host system of the ECU using a peripheral bus such as Serial Peripheral Interface (SPI). The TCB of the TPM consists only of the TPM itself because it provides its own CPU and memory. A TPM must adhere to protection profile (Trusted Computing Group, 2019a). This profile is conforming to the Common Criteria Version 3.1 and dictates mandatory tamper resistance protection measures against physical attacks. With such strong tamper resistance requirements, the TPM can mitigate all attacker types we defined. Among the evaluated HTAs, its security guarantees are the strongest. While there have been successful cyberattacks on TPMs, they are always due to implementation errors, e.g., Moghimi et al. (2020), weak standard configurations, e.g., Winter and Dietrich (2013), or vulnerabilities in TEEs that should secure a firmware TPM, e.g., Jacob et al. (2023). While the first two vulnerabilities caused by weak standard configurations or implementation errors can be easily fixed by secure software updates, the last one depends on TPM-independent (proprietary) security mechanisms and not on the TPM implementation itself. Thus, none of these attacks bypass or compromise the underlying security model of the TPM.

HSMs are security subsystems of automotive SOCs. The security and protection levels that HSMs can provide are often difficult to determine. This is due to the heterogeneous field of competing specifications such as EVITA and SHE and the fact that the implementation of the HSM is vendor-specific and most often a black box. This makes the evaluation of security guarantees difficult and error-prone (Ring et al., 2018). Typically, no Common Criteria (CC) certification and corresponding protection profiles are required. The TCB usually includes the HSM itself. If tamper-resistance is implemented, the TCB may also include parts of the host controller in which the HSM is embedded. HSMs conforming to the EVITA *light* or SHE specifications furthermore extend the TCB to the RAM, NVM, and CPU of the host controller since the specification does not require the HSM to be implemented as an isolated subsystem. Tamper protection is not mandatory for most HSMs but the EVITA *medium* and EVITA *full* profiles can mitigate cyberattacks up to a Type2 attacker because their TCB is isolated from the host controller. SHE and EVITA *light*, on the other hand, can only mitigate Type1 attackers because their TCB includes parts of the host controller. Attackers that can compromise the host controller can therefore most likely also compromise the HSM.

TrustZone is an extension for ARM processors that—in addition to the REE—creates a TEE in which security sensitive code can be executed concurrently. Its TCB includes parts of the memory and CPU of the host controller that are used by the TEE as well as the necessary modules, peripherals, and bus systems. No tamper-protection is provided, and number of critical attacks on the TrustZone implementations of multiple vendors have been discovered (Cerdeira et al., 2020). This and the rather large TCB that uses all components of the host controller show that it is easy to escalate privileges and compromise the security guarantees for a Type2 attacker. Therefore, we consider TrustZone to be secure only against Type1 attackers.

Similar to TrustZone, SGX is a processor feature found in certain Intel processors. However, unlike TrustZone, SGX offers multiple trusted

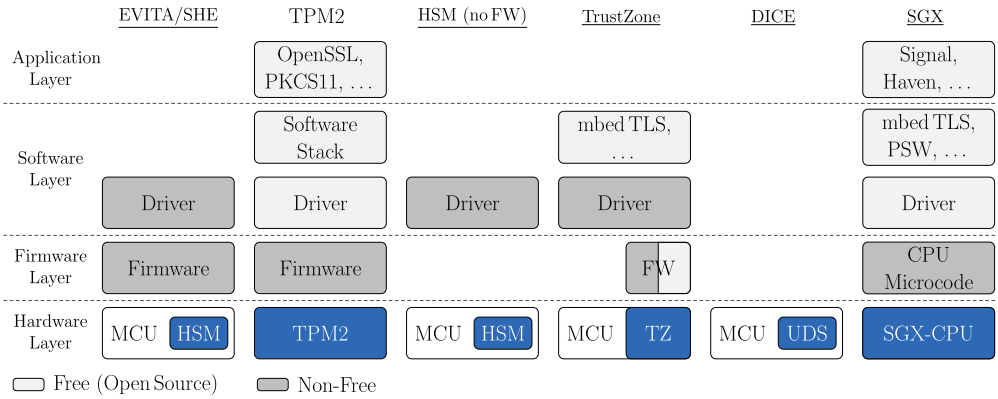

Fig. 4. HTA software module comparison.

worlds. In the trust model of SGX, only the CPU itself is deemed trustworthy, forming its TCB as described in this paper. The TCB of SGX is smaller compared to TrustZone, but high-end CPUs inherently possess more complexity than the other HTAs discussed in this paper. Consequently, the attack surface of SGX is larger compared to, for example, a TPM or DICE. SGX has faced both hardware and software attacks that have enabled the extraction of secrets (Nilsson et al., 2020). One of the recent attacks that has caught attention is the ÆPIC Leak (Borrello et al., 2022), a unique CPU vulnerability affecting Intel's 10th, 11th, and 12th generation processors. Unlike transient execution attacks such as Meltdown and Spectre, ÆPIC Leak is an architectural bug that exposes sensitive data directly, without the need for side channels. Specifically, it compromises systems relying on Intel's SGX technology by deterministically leaking essential cryptographic keys. The attack requires privileged access, making most systems inherently secure against it. However, these vulnerabilities arise from implementation weaknesses rather than an inherently weak or flawed trust model. In case of the ÆPIC Leak, mitigations include firmware and software updates aimed at preventing unauthorized data access via the Advanced Programmable Interrupt Controller (APIC) Memory-Mapped I/O (MMIO) undefined range. Generally, these implementation weaknesses can occur in any system but are more likely in complex architectures with broader attack surfaces. We consider SGX to be secure against Type1 and Type2 attackers (assuming a patched CPU that protects against the ÆPIC Leak), while still being susceptible to certain attacks by a Type3 attacker.

DICE is designed to be implemented on resource constrained devices. Consequently, it is limited in its capabilities. Simple attacks such as firmware manipulation that are for example in the range of the Type2 attacker are detected by a DICE architecture at boot time. More sophisticated runtime attacks or side channel attacks can neither be detected nor mitigated. It has been shown that it is possible to use specialized runtime attacks to permanently compromise a device (Hristozov et al., 2022). Therefore, DICE can only be used to mitigate up to certain types of Type2 attackers.

5.3. Software ecosystem

Fig. 4 gives an overview of the software ecosystems that are based on each of the analyzed HTAs.

An extensive ecosystem of free and open-source software exists around the TPM (Linux TPM2 & TSS2 Software Community, 2022). It consists of the TPM Software Stack, hardware drivers and application software such as command line tools for rapid prototyping and integration for OpenSSL and PKCS11. This software ecosystem is most prominently used in Linux distributions which provide pre-compiled software packages and use them to access the TPM in PCs, servers, and laptops. Parts of this ecosystem can easily be adapted for embedded contexts. For example, Infineon demonstrates this with the application notes for its automotive TPM development board (Infineon Technologies AG, 2020a).

The software ecosystem for EVITA HSM and SHE is typically limited to proprietary software which is not publicly accessible. Evaluation of this ecosystem is therefore difficult. Tier 1 suppliers who can access the HTAs have analyzed HSM software ecosystems (Ring et al., 2018). They conclude that advertised software is rarely production ready because functionality is not implemented, tested or usable.

Typically, no publicly available software ecosystem is provided for generic freely programmable HSMs. Therefore, both the HSM firmware and the host controller firmware must be developed additionally.

Some reference firmware is available as open-source code for TrustZone. Furthermore, a number of open-source software implementations exist (Linaro, 2022). Examples are the open-source TEE (OP-TEE) and Arm Trusted Firmware-A, both trusted OSs for TrustZone. Applications for the TEE, the Trusted Applications (TAs), must, however, be implemented. Some proprietary TEE implementations exist in the field of mobile devices, e.g., SierraTEE (Sierraware, 2022) or Samsung TEEGRIS (Samsung, 2022). These are specifically focused on mobile devices and therefore cannot be used in automotive contexts.

No publicly available generic implementation exists for DICE. This is because DICE is highly dependent on the available hardware. It is however easy to implement DICE on a given device due to the simplicity of the concept. More complex architectures based on DICE are more difficult to develop. A production-quality implementation of the Open Profile for DICE, a specialization of the generic DICE concept, exists (Google, 2023). Furthermore, a prototype implementation of Fraunhofer AISEC (2022), a DICE extension developed by Huber et al. (2020) is available.

Intel offers a comprehensive software support for SGX, providing SGX drivers, the SGX SDK, and the SGX Platform Firmware (PSW) for major desktop systems, including Linux and Windows. The software is regularly updated, demonstrating Intel's commitment to maintaining the technology. In terms of software support, Intel sets a prime example. A wide range of libraries have been ported to SGX, as evidenced by numerous repositories on platforms such as GitHub. These include popular libraries like mbed TLS for cryptographic operations. Additionally, the SGX framework/SDK offers practical utilities that assist developers in utilizing SGX effectively. For instance, the "Protected File System Library" simplifies the integration of a (virtual) file system within an enclave, seamlessly managing context switches and encryption of enclave data, which is then securely written to the hard disk. Furthermore, "Switchless Calls" optimize performance by significantly reducing the need for costly context switches between the untrusted and trusted domains, enhancing overall efficiency. On the application side, there is the prominent Signal messenger, that uses SGX for private contact discovery (Marlinspike, 2017). Other projects are Haven (Baumann et al., 2014), enabling shielded execution of unmodified legacy applications, Gramine (Tsai et al., 2017; Gramine Contributors, 2022),

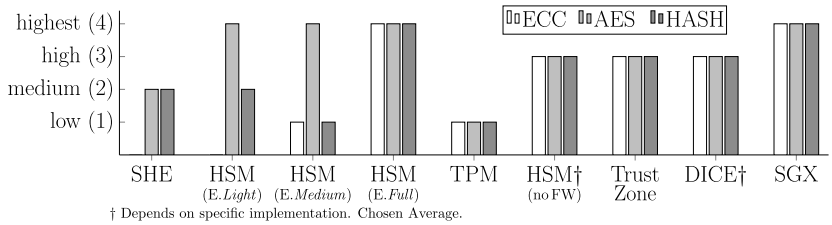

Fig. 5. Ordinal cryptographic performance comparison of the selected HTAs.

a library OS for unmodified applications on SGX, and SCONE (Arnautov et al., 2016), that provides secure Linux containers with Intel SGX.

5.4. Cryptographic performance

The ability to execute cryptographic operations is crucial for automotive HTAs with high-performance requirements, e.g. generation and verification of asymmetric signatures in use cases with V2X communication (Bottinelli and Lambert, 2019).

As stated in the background section, each HTA that we analyze is implemented in a variety of ways with different performance properties. We can therefore only rate the performance using an ordinal rating system with scores to compare the performances of the HTAs with each other. The scores range from 1 (low) over 2 (medium) and 3 (high) to 4 (highest). A rating of 1 is given to HTAs without hardware acceleration for cryptographic operations and access to a host side CPU that is faster than the HTA CPU. HTAs without hardware acceleration that can access a faster host side CPU are rated 2. A rating of 3 is given to HTAs that may have hardware accelerators or can utilize a fast application CPU to execute cryptographic operations. None of this is a mandatory requirement in the specification, though. A rating of 4 is given to HTAs with hardware accelerators for cryptographic operations being a mandatory part of the specification. The ratings for each HTA are given in Fig. 5 and detailed in the following.

The EVITA HSMs are the only HTAs that are specified to provide mandatory cryptographic hardware accelerators. Consequently, they usually have a better performance than the other HTAs. We give them a performance rating of 4. EVITA *full* provides hardware accelerators for AES and ECC. EVITA *medium* and EVITA *light* are reduced to the AES hardware accelerator. Furthermore, EVITA *light* has no support for ECC. It can, however, use the host CPU for MAC operations which is typically faster than the HSM CPU.

We also rate SGX with 4. It offers robust support for hardware accelerations for several cryptographic algorithms. However, even without hardware acceleration, SGX-enabled CPUs demonstrate remarkable computational power, enabling efficient execution of various (not only) cryptographic algorithms, that probably goes beyond the performance of HSMs.

The freely programmable HSMs score slower with a rating of 3. This is because many of them do provide hardware acceleration for cryptographic operations or have access to a faster host CPU but none of this is specified as mandatory since no unified specification exists. The rating consequently reflects the typical feature set of freely programmable HSMs.

The TrustZone is also rated 3. Since it uses most of the host CPU components its performance is higher than that of the embedded CPU of other HTAs. Typically, no hardware accelerators are included in a TrustZone.

DICE also scores a rating of 3 since it uses the resources of the host CPU. Some MCUs on which DICE can be implemented also provide hardware accelerators for cryptographic operations. The DICE specification, however, makes no mandatory requirements considering these, therefore the rating again reflects the typical feature set of a DICE implementation.

SHE is rated 2. It does not provide any cryptographic hardware accelerators and uses a host CPU that is typically slower than that of a host system with a TrustZone.

The TPM scores lowest with a rating of 1. This is because the specification does not require hardware acceleration and the hardware isolation concept does not allow access to the host CPU.

5.5. Flexibility

The generic HSMs, SGX, and TrustZone offer the highest degree of flexibility among the analyzed HTAs due to their freely programmable nature. DICE architectures are also freely programmable but due to the minimal set of hardware features on which it is based it can provide a limited feature set. Therefore, it is rated lower than generic HSMs and the TrustZone.

The other HTAs that we analyzed have a fixed feature set and are less flexible regarding the provided security services. The TPM is an exception to this observation because it is designed with crypto-agility in mind which makes the addition of new cryptographic algorithms and primitives generally possible. The cryptographic registry for the TPM reflects this. It is constantly updated with new cryptographic algorithms and primitives (Trusted Computing Group, 2018a). Furthermore, academic research is conducted that will add post-quantum cryptography to the TPM specification (Niederhagen et al., 2021; Future TPM Consortium, 2022).

5.6. Cost

The cost evaluation considers two main cost factors: Hardware and software cost. The software stack comparison shown in Fig. 4 shows that the software ecosystem for the TPM is mostly open source. In most cases, this outweighs the hardware costs of including the TPM. SGX is similar in this regard, providing the entire software stack, including the driver, libraries, and applications, as open-source software. SGX, however, has higher hardware costs than the TPM.

The hardware costs of DICE are minimal since it requires features that are already provided by many standard MCUs. A generic implementation of a DICE architecture called “Open Profile for DICE” (Google, 2023) is publicly available and provides production-quality code. If this does not fit, a custom implementation must be created. The cost of this mostly depends on the feature set that a DICE-based architecture is supposed to provide.

For all other HTAs the hardware costs are low because they are security subsystems of TEEs that are already present in the microcontroller, host system, or CPU. Usually, this leads to lower hardware costs than for example the addition of hardware that a TPM causes. Our software ecosystem analysis (cf. Section 5.3) shows that most of the software components required to integrate these modules are not publicly available. Mostly they are proprietary and need to be licensed which causes additional costs. In some cases, the provided software stack is not even fully operational due to a lack of features or testing as our analysis of related work (Ring et al., 2018) shows. This requires additional effort to tailor software solutions to the state of the provided stack which drives the software cost up. In many cases, this outweighs the lower hardware cost.

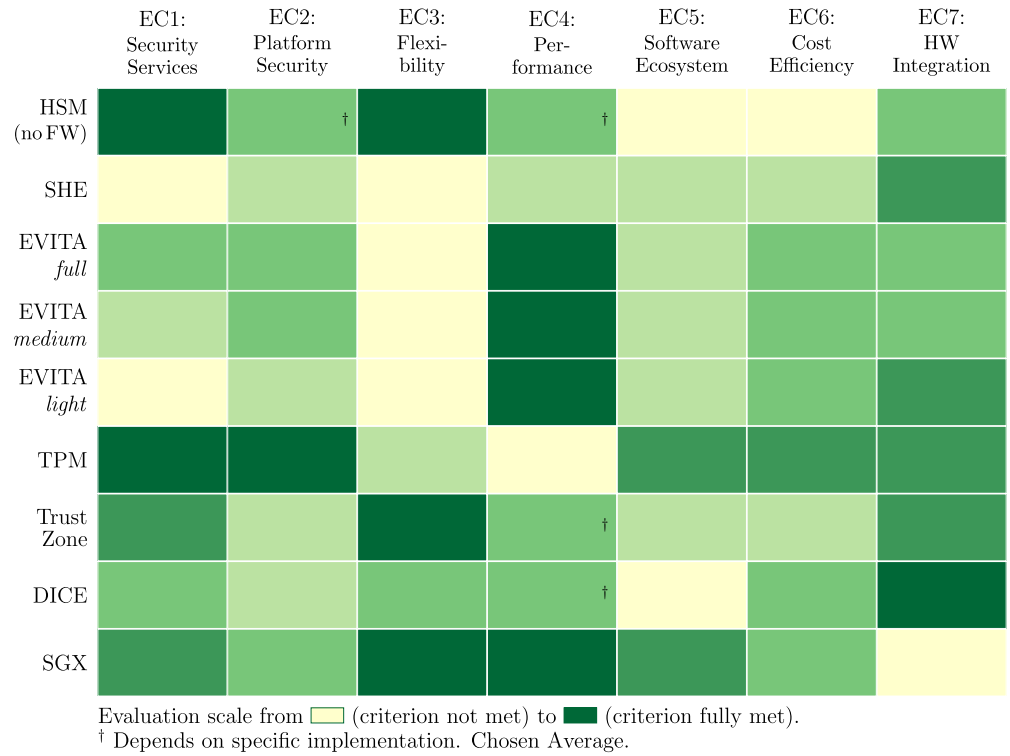

Fig. 6. HTA evaluation heatmap.

5.7. Hardware integration

The hardware integration criterion covers both the cost and flexibility of integrating the hardware required for the HTA, as well as the energy efficiency for integrating them in resource constrained devices.

DICE fulfills this criterion to a high degree. It requires only hardware that already exists in most ECUs, and because it runs entirely in the host environment it is as efficient as the host CPU. TrustZone requires more specialized hardware which however already has a reasonable distribution among embedded devices due to the increasing usage of the Armv8-M architecture (Cortex-M23 and Cortex-M33). SGX is also freely programmable, but requires the system to be based on an Intel CPU, which is typically incompatible with existing automotive architectures and especially its resource constraint subnetworks due to energy usage or cost of integration.

The TPM, EVITA and the SHE HSMs all require specialized hardware, but have a reasonable cost of integration and energy-efficiency as demonstrated by their widespread use in automotive architectures. The TPM requires specialized hardware, but can be added as an add-on via an existing bus system. EVITA and SHE HSMs need to be integrated into the host system, but they are already in use in many automotive ECUs. Of those, EVITA *light* and SHE require less hardware to using the host CPU and in general lower requirements from the specification.

6. Result summary and discussion

In this section, we summarize our findings and introduce a score ranging from criterion not met to criterion fully met to depict the degree to which our evaluation criteria are met. An overview of the scores is visualized in Fig. 6.

Regarding the provided security services (EC1), only TPM and in some cases an HSM without firmware can support all use cases and thus receive the highest rating; with the TPM also having an agile specification. The freely programmable TrustZone and SGX are flexible, but usually lack support for hardware features like an HWDT, resulting in a slightly lower rating. DICE and EVITA *full* are rated even lower because of limitations of the DICE concept and a generally more restricted feature set in case of EVITA *full*. EVITA *medium* provides even less features, and EVITA *light* and SHE have the most restricted feature set of all analyzed HTAs resulting also in the lowest rating for EC1.

Regarding the provided platform security guarantees (EC2), the TPM receives the highest rating, since it is a dedicated security chip with the smallest TCB. It also includes tamper-protection, an open and well-evaluated specification, and certification of both software and hardware. Thus, it mitigates against all of our defined attacker types. All other HTAs obtain a lower rating since platform security properties are not (openly) specified or certified and trust in the controller manufacturer is necessary. Of those, EVITA *full* and EVITA *medium* have a dedicated CPU and RAM and thus mitigate against up to Type2 attackers. They receive a medium rating. SGX mitigates against Type1 and Type2 attackers, but its complexity also makes weaknesses more likely resulting only in a medium score. With its big TCB, where by design all components of the host controller are shared with the secure world, TrustZone has similar complexity and thus also receives only a medium rating. EVITA *light* and SHE share resources with the host controller extending the TCB even further so that they mitigate only against Type1 attackers. Still, it protects against Type1 attackers. DICE also receives the low rating due to the limited security guarantees that only protect against Type1 (and certain Type2) attackers.

Regarding flexibility (EC3), freely programmable HTAs, like HSM without firmware, TrustZone and SGX, can easily be adapted to system requirements regarding supported features, giving them the highest rating. DICE is rated medium due to the limitations of the typically most resource constrained underlying hardware platform. All other HTAs have a fixed feature set and thus are rated with the lowest score. The TPM is an exception here, where at least the specification is designed to be extensible. Some manufacturers also enhance SHE and EVITA feature sets by adding additional cryptographic algorithms and primitives, but their specification details are, if existing, not publicly available.

Therefore, their underlying security guarantees or deviations from the original specification are not verifiable.

Regarding the performance criterion (EC4), HTAs with cryptographic accelerators, which are EVITA *full*, EVITA *medium* and EVITA *light*, receive the highest rating. Also, SGX receives the highest rating for its high degree of performance. For the other freely programmable HTAs (HSM, TrustZone and DICE) we assume a medium rating since their real performance depends on their implementation. SHE has no cryptographic accelerators but uses the typically faster host controller CPU and thus scores at least slightly higher than the TPM, which has no accelerators and uses its own typically slow CPU, making it the slowest HTA of those analyzed. However, there are possibilities of a TPM-backed software processing with obvious security tradeoffs.

Regarding the software ecosystem (EC5), a wide range of free and open-source software is available for the TPM, comprising firmware, driver, software stack as well as application software. The situation for SGX is similar. For the HSM and SHE, available firmware is mostly proprietary and then only commercially available. ARM provides open-source firmware and software reference implementations for TrustZone, but commercially available solutions are mostly bundled with commercially, non-free firmware and additional software also needs to be implemented. There is no software available for DICE.

The cost efficiency criterion is achieved best for the TPM. Its software costs are small due to the high degree of available software, while the hardware costs are reasonable. The latter is also true for EVITA HSMs, but its software ecosystem is much smaller, giving it only a medium score. DICE offers even less software, but is cheap in terms of hardware. SGX has a good availability of software, but its hardware is costly. TrustZone fares well in terms hardware costs, but its software is often not easily available. For EVITA and SHE HSMs the situation is similar. HSMs without firmware are freely programmable and typically do not have any available software.

The hardware integration criterion is best fulfilled by DICE. Its hardware is minimal so that most MCUs can implement it, and it is appropriately energy-efficient for resource constrained devices. The TPM receives a rating of slightly lower rating as it can be added as an add-on to existing bus systems. TrustZone receives a similar rating because it is already integrated into some MCUs used in embedded systems, while SHE and EVITA *light* HSMs have a small hardware cost and are also already integrated in many automotive ECUs. HSMs without firmware, EVITA *medium* and EVITA *full* have a higher hardware cost, but are also already integrated in many automotive ECUs. SGX receives the lowest score because its hardware costs and energy consumption make it unsuitable for automotive ECUs.

Overall, our summarized evaluation results elaborate on both advantages and disadvantages of the analyzed HTAs regarding our defined evaluation criteria. Because of the different HTA advantages, hybrid approaches utilizing a variety of different HTAs are an appropriate option to further increase the security of future vehicle architectures. Our heatmap depicted in Fig. 6 summarizes the core strengths of each HTA. A possible hybrid security architecture could then consist of a centrally placed TPM that acts as vehicle trust anchor due to its strong security guarantees. Its secure key generator and general key management functionalities make it valuable as primary security provider and policy enforcement point in the vehicle. Its secure session, key duplication and key derivation features can be used to (re-) provision credentials of HTAs with lower security guarantees, which then in turn provide functionality that a TPM does not support. For example, the fast processing HTAs SGX, TrustZone, and the EVITA HSMs may be utilized to carry out high-performance use cases, e.g., symmetric bulk encryption, while the freely programmable HTAs may be used to secure the execution of arbitrary software. Additionally, on the most resource-constrained hardware where dedicated HTAs are not feasible to be used, e.g., due to cost or hardware feature limitations, DICE becomes a feasible security mechanism to increase the security guarantees of these small devices significantly. While benefits of such hybrid architectures are obvious, challenges arise during the interconnection of the different HTAs. Here, open specifications of TPM and DICE contribute for easy integration. The developed software of freely programmable HTAs like SGX, TrustZone, and the HSM need to comply with these open specifications, while HTAs with a fixed feature set like SHE and the EVITA HSMs are harder to be integrated. Here, a more in-depth analysis of compatibility between their standards is necessary.

7. Conclusion

In this work, we have evaluated the applicability of Hardware Trust Anchors (HTAs) to secure current and expected upcoming automotive architectures and use cases. We conducted an automotive domain analysis to derive an automotive reference architecture with a corresponding threat and attacker model as well as prominent use cases that are relevant to current and future automotive architectures. Based on this analysis and related work, we derived our evaluation criteria. We select currently established as well as promising new HTA technologies and execute our evaluation process by analyzing the applicability of the selected HTAs based on our derived evaluation criteria.

The results of our evaluation have shown the corresponding advantages and disadvantages of the analyzed HTAs according to the different evaluation criteria. While the results indicate that already established automotive HTAs are feasible to secure current automotive use cases, they lack of certain features like tamper protection, high-performance processing or redundancy and safety features that are crucial for upcoming use cases. The TPM that is not yet widespread in vehicle architectures has shown to be compliant to both the EVITA and SHE feature sets and has also some important advanced (hardware) security features that cannot be emulated in software by any of the analyzed freely programmable HTAs. This makes the TPM a reasonable choice to secure also upcoming automotive use cases. The results have shown that DICE is primarily interesting for legacy ECUs, where other HTAs are not feasible to be deployed because of cost or resource constraints or do not support all required security services. SGX has shown to be feasible to secure resource-intense future use cases that require the secure execution of security and safety-critical software on the more powerful vehicle backbone network.

CRediT authorship contribution statement

Christian Plappert: Conceptualization, Investigation, Methodology, Supervision, Visualization, Writing – original draft. **Dominik Lorych:** Investigation, Visualization, Writing – original draft. **Michael Eckel:** Investigation, Writing – original draft. **Lukas Jäger:** Writing – review & editing. **Andreas Fuchs:** Resources. **Ronald Heddergott:** Resources.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

No data was used for the research described in the article.

Acknowledgement

This work has been partly funded by the German Federal Ministry of Education and Research (BMBF) projects FINESSE (ID 16KIS1586), HardShiP (ID 16KIS1795), ASCOT (ID 16ME0274), and the German Federal Ministry for Economic Affairs and Climate Action (BMWK) project ELISA (ID 19S23002E).

Acronyms			
ACE	Asymmetric Cryptographic Engine	MMIO	Memory-Mapped I/O
AES	Advanced Encryption Standard	NVM	Non-Volatile memory
APIC	Advanced Programmable Interrupt Controller	OEM	Original Equipment Manufacturer
AUTOSAR	Automotive Open System Architecture	OS	Operating System
AWDT	Authenticated Watchdog Timer	PCR	Platform Configuration Register
CAN	Controller Area Network	PKI	Public Key Infrastructure
CC	Common Criteria	PRNG	Pseudo Random Number Generator
CDI	Compound Device Identifier	RAM	Random-Access Memory
CHF	Cryptographic Hash Function	REE	Rich Execution Environment
CMAC	Cipher-based Message Authentication Code	RNG	Random Number Generator
CoT	Chain of Trust	RoT	Root of Trust
CPU	Central Processing Unit	RTE	Root of Trust for Execution
CRTM	Core Root of Trust Measurement	RTM	Root of Trust for Measurement
DH	Diffie–Hellman	RTR	Root of Trust for Reporting
DICE	Device Identifier Composition Engine	RTS	Root of Trust for Storage
E / E	Electrical / Electronic	SCE	Symmetric Cryptographic Engine
ECC	Elliptic Curve Cryptography	SecOC	Secure Onboard Communication
ECR	ECU Configuration Register	SEV	Secure Encrypted Virtualization
ECU	Electronic Control Unit	SGX	Software Guard Extensions
GP	GlobalPlatform	SHE	Secure Hardware Extension
HIS	Herstellerinitiative Software	SOC	System on Chip
HMAC	Hash-based Message Authentication Code	SPI	Serial Peripheral Interface
HPC	High-Performance Computer	TA	Trusted Application
HSE	Hardware Security Engine	TCB	Trusted Computing Base
HSM	Hardware Security Module	TCG	Trusted Computing Group
HTA	Hardware Trust Anchor	TDX	Trust Domain Extensions
HWDT	Hardware Watchdog Timer	TEE	Trusted Execution Environment
IC	Integrated Circuit	TLS	Transport Layer Security
ICL	Internal Clock	TPM (2.0)	Trusted Platform Module (2.0)
ICU	Intelligent Cryptographic Unit	TRNG	True Random Number Generator
KMA	Key Management	UDS	Unique Device Secret
KUS	Key Usage	UTC	Universal Time Coordinated
MAC	Message Authentication Code	UUID	Universally Unique Identifier
MCU	Microcontroller Unit	V2X	Vehicle-to-Everything
		vECU	Virtual ECU

References

Advanced Micro Devices, Inc. AMD secure encrypted virtualization (SEV). https://www.amd.com/en/developer/sev.html.

Arm Limited TrustZone for cortex-A. https://www.arm.com/technologies/trustzone-for-cortex-a/tee-and-smc.

Arm Limited TrustZone for cortex-M. https://www.arm.com/technologies/trustzone-for-cortex-m.

Arm Limited TrustZone for cortex-A: technical specifications. https://developer.arm.com/Processors/TrustZone%20for%20Cortex-A#Technical-Specifications.

Arm Limited TrustZone for cortex-M: technical specifications. https://developer.arm.com/Processors/TrustZone%20for%20Cortex-M#Technical-Specifications.

Arnautov, S., Trach, B., Gregor, F., Knauth, T., Martin, A., Priebe, C., Lind, J., Muthukumaran, D., O'Keeffe, D., Stillwell, M.L., Goltzsche, D., Eyers, D., Kapitza, R., Pietzuch, P., Fetzer, C., 2016. SCONE: secure Linux containers with Intel SGX. In: 12th USENIX Symposium on Operating Systems Design and Implementation (OSDI 16). USENIX Association, Savannah, GA, pp. 689–703. https://www.usenix.org/conference/osdi16/technical-sessions/presentation/arnautov.

Baumann, A., Peinado, M., Hunt, G., 2014. Shielding applications from an untrusted cloud with haven. In: 11th USENIX Symposium on Operating Systems Design and Implementation (OSDI 14). USENIX Association, Broomfield, CO, pp. 267–283. https://www.usenix.org/conference/osdi14/technical-sessions/presentation/baumann.

Borrello, P., Kogler, A., Schwarzl, M., Lipp, M., Gruss, D., Schwarz, M., 2022. ÆPIC leak: architecturally leaking uninitialized data from the microarchitecture. In: 31st USENIX Security Symposium (USENIX Security 22). USENIX Association, Boston, MA, pp. 3917–3934. https://www.usenix.org/conference/usenixsecurity22/presentation/borrello.

Bottinelli, P., Lambert, R., 2019. Accelerating V2X Cryptography through Batch Operations. IACR Cryptol. ePrint Arch. 2019/887.

Cerdeira, D., Santos, N., Fonseca, P., Pinto SoK, S., 2020. Understanding the prevailing security vulnerabilities in TrustZone-assisted TEE systems. In: 2020 IEEE Symposium on Security and Privacy (SP), pp. 1416–1432.

Confidential Computing Consortium. https://confidentialcomputing.io/.

Dibaei, M., Zheng, X., Jiang, K., Abbas, R., Liu, S., Zhang, Y., Xiang, Y., Yu, S., 2020. Attacks and defences on intelligent connected vehicles: a survey. Digit. Commun. Netw. 6 (4), 399–421. https://doi.org/10.1016/j.dcan.2020.04.007.

Dolev, D., Yao, A.C., 1981. On the security of public key protocols. In: Proceedings of the 22Nd Annual Symposium on Foundations of Computer Science, SFCS '81. IEEE Computer Society, Washington, DC, USA, pp. 350–357.

Eckel, M., Basu, A., Kai, S., Simo Fhom, H., Dukanovic, S., Birkholz, H., Hane, S., Lieske, M., 2023. SCATMAN: a framework for enhancing trustworthiness in digital supply chains. In: 2023 IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom).

Escherich, R., Ledendecker, I., Schmal, C., Kuhls, B., Grothe, C., Scharberth, F., 2009. SHE – Secure Hardware Extension Functional Specification Version 1.1, Rev: 439.

Evita Consortium Evita deliverable D3.2: secure on-board architecture specification. https://evita-project.org/Deliverables/EVITAD3.2.pdf.

Evita Consortium EVITA E-safety vehicle intrusion protected applications. https://evita-project.org.

Felton, D., 2019. What is a trusted execution environment (TEE)? https://www.trustonic.com/news/technology/what-is-a-trusted-execution-environment-tee/.

Fenzl, F., Plappert, C., Rieke, R., Zelle, D., Costantino, G., De Vincenzi, M., Matteucci, I., 2023. Collaborative Security Patterns for Automotive Electrical/Electronic Architecture. Springer International Publishing, Cham, pp. 63–97.

Fraunhofer AISEC, 2022. Lazarus prototype implementation. https://github.com/Fraunhofer-AISEC/lazarus.

Fuchs, A., Birkholz, H., McDonald, I., Bormann, C., 2022. Time-based uni-directional attestation. https://datatracker.ietf.org/doc/html/draft-birkholz-rats-tuda-07.

Future TPM Consortium Future proofing the connected world: a quantum-resistant trusted platform module. https://futuretpm.eu/.

GlobalPlatform, 2017. TEE system architecture v1.1. https://globalplatform.org/wp-content/uploads/2018/06/GPD_TEE_SystemArch_v1.1_Public_Release.pdf.

GlobalPlatform, 2021. TEE internal core API specification v1.3.1. https://globalplatform.org/specs-library/tee-internal-core-api-specification/.

Google, 2023. Open profile for DICE. https://pigweed.googlesource.com/open-dice/. Not an officially supported Google product.

Gramine Contributors Gramine - a library OS for unmodified applications. https://gramineproject.io/.

Greenberg, A., 2015. Hackers remotely kill a Jeep on the highway - with me in it. https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/.

Hex Five Security, Inc. MultiZone security for RISC-V. https://hex-five.com/multizone-security-tee-riscv/.

Hristozov, S., Wettermann, M., Huber, M., 2022. A TOCTOU attack on DICE attestation. In: Proceedings of the Twelfth ACM Conference on Data and Application Security and Privacy, CODASPY '22. Association for Computing Machinery, New York, NY, USA, pp. 226–235.

Hu, Q., Luo, F., 2018. Review of secure communication approaches for in-vehicle network. Int. J. Automot. Technol. 19 (5), 879–894. https://doi.org/10.1007/s12239-018-0085-1.

Huber, M., Hristozov, S., Ott, S., Sarafov, V., Peinado, M., 2020. The Lazarus effect: healing compromised devices in the Internet of small things. In: Proceedings of the 15th ACM Asia Conference on Computer and Communications Security.

Infineon Technologies AG A safe for sensitive data in the car: Volkswagen relies on TPM from Infineon. https://www.infineon.com/cms/en/about-infineon/press/market-news/2019/INFATV201901-030.html.

Infineon Technologies AG OPTIGA TPM SLI 9670 A-TPM board. https://www.infineon.com/cms/de/product/evaluation-boards/optiga-tpm-sli9670-a-tpm/.

Infineon Technologies AG AURIX 32-bit microcontrollers for automotive and industrial applications. https://www.infineon.com/cms/en/product/microcontroller/32-bit-tricore-microcontroller/aurix-security-solutions/#!?fileId=5546d4625d5945ed015dc81f47b436c7.

Infineon Technologies AG. OPTIGA TPM SLI 9670 TPM2.0. https://www.infineon.com/dgdl/Infineon-SLI%209670-DataSheet-v01_20-EN.pdf?fileId=5546d46269e1c019016ad57885d4700e&da=t.

Intel Corporation Intel software guard extensions (Intel SGX). https://www.intel.com/content/www/us/en/architecture-and-technology/software-guard-extensions.html.

Intel Corporation Intel trust domain extensions (Intel TDX). https://www.intel.com/content/www/us/en/developer/articles/technical/intel-trust-domain-extensions.html.

Intel Corporation Intel architecture instruction set extensions programming reference, version 48. https://www.intel.com/content/www/us/en/content-details/774990/intel-architecture-instruction-set-extensions-programming-reference.html.

Isermann, R., Schwarz, R., Stolzl, S., 2002. Fault-tolerant drive-by-wire systems. IEEE Control Syst. Mag. 22 (5), 64–81. https://doi.org/10.1109/MCS.2002.1035218.

Jacob, H.N., Werling, C., Buhren, R., Seifert, J.-P., 2023. faultpm: exposing amd ftpms' deepest secrets. arXiv:2304.14717.

Keystone Enclave Keystone – an open framework for architecting trusted execution environments. https://keystone-enclave.org/.

Lear, E., Tschofenig, H., 2018. Defining and enabling confidential computing. https://confidentialcomputing.io/wp-content/uploads/sites/85/2019/12/CCC_Overview.pdf.

Li, Z., Li, W., Xia, Y., Zang, B., 2020. TEEp: supporting secure parallel processing in ARM TrustZone. In: 2020 IEEE 26th International Conference on Parallel and Distributed Systems (ICPADS), pp. 544–553.

Linaro, 2022. Open source secure software. https://www.trustedfirmware.org/.

Linux Kernel Newbies More secure virtualization with amd's sev-snp and Intel's tdx. https://kernelnewbies.org/Linux_5.19#More_secure_virtualization_with_AMD.27s_SEV-SNP_and_Intel.27s_TDX.

Linux TPM2 & TSS2 Software Community Linux TPM2 & TSS2 software. https://github.com/tpm2-software/.

MAN, 2023. MAN Truck & Bus to make city buses autonomous with Mobileye. https://press.mantruckandbus.com/corporate/man-truck--bus-to-make-city-buses-autonomous-with-mobileye/.

Marlinspike, M., 2017. Technology preview: private contact discovery for Signal. https://signal.org/blog/private-contact-discovery/.

McCandless, D., Barton, P., Bergamaschi, F., Evans, T., Jobey, R., Kashan, O., Starling, S., Ruch, K., 2015. Codebases - millions of lines of code. https://informationisbeautiful.net/visualizations/million-lines-of-code/.

Moghimi, D., Sunar, B., Eisenbarth, T., Heninger, N., 2020. TPM-FAIL: TPM meets timing and lattice attacks. In: 29th USENIX Security Symposium (USENIX Security 20). USENIX Association, Boston, MA. https://www.usenix.org/conference/usenixsecurity20/presentation/moghimi.

Niederhagen, R., Roth, J., Wälde, J., 2021. Streaming SPHINCS+ for embedded devices using the example of TPMs. Cryptology ePrint Archive, Report 2021/1072 https://ia.cr/2021/1072.

Nilsson, A., Bideh, P.N., Brorsson, J., 2020. A survey of published attacks on Intel SGX. arXiv:2006.13598.

NXP Semiconductors Security subsystems for systems-on-chip (SoCs). aITOEDGEWP REV 1. https://www.nxp.com/docs/en/white-paper/Security-Subsystems-WP.pdf.

Osborne, C., 2018. How to steal a Tesla Model S in seconds. https://www.zdnet.com/article/how-to-steal-a-tesla-model-s-in-seconds/.

Plappert, C., Jäger, L., Fuchs, A., 2021a. Secure role and rights management for automotive access and feature activation. In: Proceedings of the 2021 ACM Asia Conference on Computer and Communications Security, ASIA CCS '21. Association for Computing Machinery, New York, NY, USA, pp. 227–241.

Plappert, C., Zelle, D., Gadacz, H., Rieke, R., Scheuermann, D., Krauß, C., 2021b. Attack surface assessment for cybersecurity engineering in the automotive domain. In: 2021 29th Euromicro International Conference on Parallel, Distributed and Network-Based Processing (PDP). IEEE, Valladolid, Spain, pp. 266–275.

Plappert, C., Fenzl, F., Rieke, R., Matteucci, I., Costantino, G., De Vincenzi, M., 2022a. SECPAT: security patterns for resilient automotive E / E architectures. In: 2022 30th Euromicro International Conference on Parallel, Distributed and Network-Based Processing (PDP), pp. 255–264.

Plappert, C., Fuchs, A., Heddergott, R., 2022b. Analysis and evaluation of hardware trust anchors in the automotive domain. In: Proceedings of the 17th International Conference on Availability, Reliability and Security, ARES '22. Association for Computing Machinery, New York, NY, USA.

Porsche AG Porsche and Mobileye announce collaboration. https://newsroom.porsche.com/en/2023/company/porsche-mobileye-collaboration-automated-driver-assistance-functions-32250.html.

RATS Working Group TPM-based network device remote integrity verification. https://datatracker.ietf.org/doc/html/draft-ietf-rats-tpm-based-network-device-attest-00. (Accessed 13 July 2021).

Renesas, 2016. Renesas electronics delivers RH850/E1M-S2 32-Bit MCUs for improved automobile fuel efficiency in vehicle powertrain control applications. https://www.renesas.com/us/en/about/press-room/renesas-electronics-delivers-rh850e1m-s2-32-bit-mcus-improved-automobile-fuel-efficiency-vehicle.

Ring, M., Frkat, D., Schmiedecker, M., 2018. Cybersecurity evaluation of automotive E/E architectures. In: ACM Computer Science in Cars Symposium (CSCS 2018).

Rocchetto, M., Tippenhauer, N.O., 2016. CPDY: extending the Dolev-Yao attacker with physical-layer interactions. In: International Conference on Formal Engineering Methods. Springer, Tokyo, Japan, pp. 175–192.

Roscher, S., Bönisch, V., Lee, J., Zeisberg, D., Schweflinghaus, J., 2018. Integrating solutions on IBM Z with secure service container. IBM J. Res. Dev. 62 (2/3), 3:1–3:6. https://doi.org/10.1147/JRD.2018.2795899.

Samsung, 2022. Samsung TEEGRIS. https://developer.samsung.com/teegris/overview.html.

Sierraware, 2022. SierraTEE trusted execution environment. https://www.sierraware.com/open-source-ARM-TrustZone.html.

Simacsek, B., 2019. Can we trust our cars? aUTOSECWP REV 0. https://www.nxp.com/docs/en/white-paper/AUTOSECWP.pdf.

The kernel development community Intel trust domain extensions (tdx). https://www.kernel.org/doc/html/next/x86/tdx.html.

The kernel development community Tdx guest api documentation. https://www.kernel.org/doc/html/next/virt/coco/tdx-guest.html.

Trusted Computing Group TPM software stack (TSS). https://trustedcomputinggroup.org/work-groups/software-stack/.

Trusted Computing Group TCG algorithm registry. https://trustedcomputinggroup.org/resource/tcg-algorithm-registry/.

Trusted Computing Group TCG protection profile for PC client specific TPM 2.0. https://trustedcomputinggroup.org/resource/pc-client-protection-profile-for-tpm-2-0/.

Trusted Computing Group TPM 2.0 library specification. https://trustedcomputinggroup.org/resource/tpm-library-specification/.

Trusted Computing Group DICE Layering Architecture. Tech. Rep.. Trusted Computing Group. https://trustedcomputinggroup.org/wp-content/uploads/DICE-Layering-Architecture-r19_pub.pdf.

Trusted Computing Group Hardware Requirements for a Device Identifier Composition Engine. Tech. Rep.. Trusted Computing Group. https://trustedcomputinggroup.org/wp-content/uploads/Hardware-Requirements-for-Device-Identifier-Composition-Engine-r78_For-Publication.pdf.

Tsai, C. che, Porter, D.E., Vij, M., 2017. Graphene-SGX: a practical library OS for unmodified applications on SGX. In: 2017 USENIX Annual Technical Conference (USENIX ATC 17). USENIX Association, Santa Clara, CA, pp. 645–658. https://www.usenix.org/conference/atc17/technical-sessions/presentation/tsai.

Winter, J., Dietrich, K., 2013. A hijacker's guide to communication interfaces of the trusted platform module. In: eUROPKI-2011. Comput. Math. Appl. 65 (5), 748–761. https://doi.org/10.1016/j.camwa.2012.06.018.

Wolf, M., Gendrullis, T., 2012. Design, implementation, and evaluation of a vehicular hardware security module. In: Kim, H. (Ed.), Information Security and Cryptology - ICISC 2011. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 302–318.

Wu, Z., Zhao, J., Zhu, Y., Lu, K., Shi, F., 2019. Research on in-vehicle key management system under upcoming vehicle network architecture. Electronics 8 (9). https://doi.org/10.3390/electronics8091026. https://www.mdpi.com/2079-9292/8/9/1026.

Xu, M., Huber, M., Sun, Z., England, P., Peinado, M., Lee, S., Marochko, A., Mattoon, D., Spiger, R., Thom, S., 2019. Dominance as a new trusted computing primitive for the Internet of things. In: 2019 IEEE Symposium on Security and Privacy (SP), pp. 1415–1430.

Zelle, D., Rieke, R., Plappert, C., Krauß, C., Levshun, D., Chechulin, A., 2020. SEPAD — security evaluation platform for autonomous driving. In: 2020 28th Euromicro International Conference on Parallel, Distributed and Network-Based Processing (PDP), pp. 413–420.